

SCHEDULE B- PRICING

Bidder is encouraged provide a percentage discount off list pricing for all offerings requested under this solicitation.

BIDDER RESPONSE:

Please see the file, *Schedule B Pricing-Oracle.docx*, included with Oracle's response.

Additional Pricing Terms

The Contractor is encouraged to offer quick payment terms. The number of days must not include processing time for payment to be received by the Contractor's financial institution.

Quick payment terms: _____ % discount off invoice if paid within _____ days after receipt of invoice.

If Contractor reduces its prices, or offers a lower price to any other entity, private or public, for any of the Solution during the term of this Contract, the State shall have the immediate benefit of such lower prices for new purchases. Contractor shall send notice to the State's Contract Administrator with the reduced prices within fifteen (15) Business Days of the reduction taking effect.

Invoice Requirements

All invoices submitted to the State must include: (a) date; (b) purchase order or delivery order; (c) quantity; (d) description of the Solution; (e) unit price; (f) shipping cost (if any); (g) Contractor-generated invoice number and (h) total price.

Travel and Expenses

The State does not pay for overtime or travel expenses.

Enter company name here Oracle

SCHEDULE C- INSURANCE REQUIREMENTS

Request For Proposal No. 250000000414
Cloud Services RFP

BIDDER INSTRUCTIONS

Do you accept these Insurance provisions as presented?

BIDDER RESPONSE:

No. While your business is important to us, You should not construe, nor does Oracle consider, the response to be legally binding upon Oracle. To the extent Oracle's insurance policies may differ from the proposed insurance requirements, Oracle has provided redlines reflecting its specific exceptions. In the event of down-selection or an award, Oracle looks forward to discussing mutually agreeable contract terms with the State as part of the resulting post-award contract negotiations.

If Bidder takes exceptions to these provisions, bidder must redline these terms as part of its proposal response. Exceptions to the terms may be grounds for disqualification at the State's discretion. General statements, such as that the Bidder reserves the right to negotiate the terms and conditions, may be deemed non-responsive.

1. General Requirements. Contractor, at its sole expense, must maintain the insurance coverage as specified herein for the duration of the Term. Minimum limits may be satisfied by any combination of primary liability, umbrella or excess liability, and self-insurance coverage. ~~To the extent damages are covered by any required insurance, Contractor waives all rights against the State for such damages. Failure to maintain required insurance does not limit this waiver.~~

2. Qualification of Insurers. Except for self-insured coverage, all policies must be written by an insurer with an A.M. Best rating of A- VII or higher unless otherwise approved by DTMB Enterprise Risk Management.

Oracle may select a new insurance carrier or carriers or may obtain new or amended policies at any time.

3. Primary and Non-Contributory Coverage. All policies for which the State of Michigan is required to be named as an additional insured must be on a primary and non-contributory basis.

4. Claims-Made Coverage. If any required policies provide claims-made coverage, Contractor must:

- Maintain coverage ~~until and provide evidence of coverage for at least 3 years after the later of~~ the expiration or termination of the Contract or the completion of all its duties under the Contract;
- Provide notification ~~Purchase extended reporting coverage for a minimum of 3 years after completion of work~~ if coverage is cancelled or not renewed, and not replaced with another claims-made policy form with a retroactive date prior to the Effective Date of this Contract.

5. Proof of Insurance.

- Insurance certificates or other documentation showing evidence of coverage as required herein must be submitted to DTMB-RiskManagement@michigan.gov within ~~49~~30 days of the contract execution date.
- Renewal insurance certificates or other documentation must be provided on annual basis or as otherwise commensurate with the effective dates of coverage for any insurance required herein.
- Insurance certificates must be in the form of a standard ACORD Insurance Certificate unless otherwise approved by DTMB Enterprise Risk Management.
- All insurance certificates must clearly identify the Contract Number (e.g., notated under the Description of Operations on an ACORD form).
- The State may require additional proofs of insurance or solvency, ~~including but not limited to policy declarations, policy endorsements, policy schedules, self-insured certification/authorization, and balance sheets.~~ Oracle will review requests for such documentation and provide documentation as is reasonable.

Commented [JB1]: Oracle: Oracle does not agree to maintain insurance after a contract terminates or expires when it will not be providing any products or services to the customer and receiving fees.

f. In the event any required coverage is cancelled or not renewed, Contractor must provide written notice to DTMB Enterprise Risk Management no later than 5 Business Days following such cancellation or nonrenewal.

6. Subcontractors. Contractor is responsible for ensuring its subcontractors carry and maintain insurance coverage.

7. Limits of Coverage & Specific Endorsements.

Required Limits	Additional Requirements
Commercial General Liability Insurance	
Minimum Limits: \$1,000,000 Each Occurrence \$1,000,000 Personal & Advertising Injury \$2,000,000 Products/Completed Operations \$2,000,000 General Aggregate	Contractor must have their policy endorsed to add "the State of Michigan, its departments, divisions, agencies, offices, commissions, officers, employees, and agents" as additional insureds using endorsement CG 20 10 11 85, or both CG 20 10 12 19 and CG 20 37 12 19.
Automobile Liability Insurance	
If a motor vehicle is used in relation to the Contractor's performance, the Contractor must have vehicle liability insurance on the motor vehicle for bodily injury and property damage as required by law.	
Workers' Compensation Insurance	
Minimum Limits: Coverage according to applicable laws governing work activities.	Waiver of subrogation, except where waiver is prohibited by law.
Employers Liability Insurance	
Minimum Limits: \$500,000 Each Accident \$500,000 Each Employee by Disease \$500,000 Aggregate Disease	
Privacy and Security Liability (Cyber Liability) Insurance	
Minimum Limits: \$10,000,000 Each Occurrence Claim \$10,000,000 Annual Aggregate	Contractor must have their policy cover information security and privacy liability, privacy notification costs, regulatory defense and penalties, and website media content liability.
Professional Liability (Errors and Omissions) Insurance	
Minimum Limits: \$5,000,000 Each Occurrence Claim \$5,000,000 Annual Aggregate	

8. Non-Waiver. This Schedule C is not intended to and is not to be construed in any manner as waiving, restricting or limiting the liability of either party for any obligations under this Contract, including any provisions hereof requiring Contractor to indemnify, defend and hold harmless the State or Oracle's liability under the Limitation of Liability.

SCHEDULE D- SERVICE LEVEL AGREEMENT (CONTRACTOR HOSTED)

BIDDER INSTRUCTIONS

Bidder is to provide link to their Service Level Agreement.

BIDDER RESPONSE:

Oracle's service level agreement is at <https://www.oracle.com/cloud/sla/>.

SCHEDULE D – ATTACHMENT 1 – CONTACT LIST

BIDDER INSTRUCTIONS

Bidder must provide a current list of Contractor contacts and telephone numbers to enable the State to escalate its Support Requests, including: (a) the first person to contact; and (b) the persons in successively more qualified or experienced positions to provide the support sought.

BIDDER RESPONSE:

Begin Oracle Confidential Information

[Redacted contact information]

End Oracle Confidential Information

SCHEDULE E – DATA SECURITY REQUIREMENTS

BIDDER INSTRUCTIONS

Do you accept these Data Security Requirements as presented?

BIDDER RESPONSE:

No. While your business is important to us, You should not construe, nor does Oracle consider, the response to be legally binding upon Oracle. As a global cloud provider, Oracle has adopted robust data security practices and policies. To the extent those practices and policies may differ from the proposed security requirements, Oracle has provided redlines reflecting its specific exceptions. In the event of down-selection or an award, Oracle looks forwarding to discussing mutually agreeable contract terms with the State as part of the resulting post-award contract negotiations.

If Bidder takes exceptions to these provisions, bidder must redline these terms as part of its proposal response. Exceptions to the terms may be grounds for disqualification at the State's discretion. General statements, such as that the Bidder reserves the right to negotiate the terms and conditions, may be deemed non-responsive.

These data security terms are only applicable to Oracle IaaS and PaaS products generally available in the US Government Cloud Data Center.

1. Definitions. For purposes of this Schedule, the following terms have the meanings set forth below. All initial capitalized terms in this Schedule that are not defined in this **Schedule** shall have the respective meanings given to them in the Contract.

"**Contractor Security Officer**" has the meaning set forth in **Section 2** of this Schedule.

"**FedRAMP**" means the Federal Risk and Authorization Management Program, which is a federally approved risk management program that provides a standardized approach for assessing and monitoring the security of cloud products and services.

"**FISMA**" means The Federal Information Security Modernization Act of 2014 (Pub.L. No. 113-283 (Dec. 18, 2014)).

"**Hosting Provider**" means any Permitted Subcontractor that is providing any or all of the Hosted Services and/or Operating Environment under this Contract.

"**NIST**" means the National Institute of Standards and Technology.

"**PCI**" means the Payment Card Industry.

"**PSP**" or "**PSPs**" means the State's IT Policies, Standards and Procedures.

"**SSAE**" means Statement on Standards for Attestation Engagements.

"**Security Accreditation Process**" has the meaning set forth in **Section 6** of this Schedule

2. Security Officer. Contractor's personnel will ~~appoint a Contractor employee to~~ respond to the State's inquiries regarding the security of the Solution who has sufficient knowledge of the security of the Solution and the authority to act on behalf of Contractor in matters pertaining thereto ("**Contractor Security Officer**").

3. Contractor Responsibilities. Contractor is responsible for establishing and maintaining a data privacy and information security program, including physical, technical, administrative, and organizational safeguards, that is designed to:

- (a) ensure the security and confidentiality of the State Data;
- (b) protect against any anticipated threats or hazards to the security or integrity of the State Data;
- (c) protect against unauthorized disclosure, access to, or use of the State Data;
- (d) ensure the proper disposal of any State Data in Contractor's or its subcontractor's possession; and
- (e) ensure that all Contractor Personnel comply with the foregoing.

The State has established Information Technology (IT) PSPs to protect IT resources under the authority outlined in the overarching State 1305.00 Enterprise IT Policy. ~~In no case will the safeguards of Contractor's data privacy and information security program be less stringent than the safeguards used by~~

the State, as documented in the State IT policies and standards, of which the publicly available ones are at <https://www.michigan.gov/dtmb/policies/it-policies>.

This responsibility also extends to all service providers and subcontractors with access to State Data or an ability to impact the Solution. Contractor responsibilities are determined from the PSPs based on the services being provided to the State, the type of IT solution, and the applicable laws and regulations.

4. **Acceptable Use Standard.**

Contractor does not access the State's IT environment for its Oracle IaaS and PaaS products generally available in the US Government Cloud Data Center and will not be providing Professional Services under the Contract.

To the extent that Contractor has access to the State's IT environment, Contractor must comply with the State's Acceptable Use Standard, see <https://www.michigan.gov/dtmb/-/media/Project/Websites/dtmb/Law-and-Policies/IT-Policy/13400013002-Acceptable-Use-of-Information-Technology-Standard.pdf>. All Contractor Personnel will be required, in writing, to agree to the State's Acceptable Use Standard before accessing State systems or Data. The State reserves the right to terminate Contractor's and/or subcontractor(s) or any Contractor Personnel's access to State Systems if the State determines a violation has occurred.

5. **Protection of State's Information.** Throughout the Term and at all times in connection with its actual or required performance of the Services, Contractor will:

5.1 If Hosted Services are provided by a Hosting Provider, ensure each Hosting Provider maintains FedRAMP authorization for ~~all purchased~~ Hosted Services environments throughout the Term, and in the event a Hosting Provider is unable to maintain FedRAMP authorization, the State, at its sole discretion, may either a) ~~require the Contractor to move the Software and State Data to an alternative Hosting Service Provider selected and approved by the State at Contractor's sole cost and expense without any increase in Fees~~, or b) ~~immediately terminate this Contract pursuant to the termination provisions in the Contract [CSA Section 9] for cause~~;

5.2 for Hosted Services provided by the Contractor, maintain either a FedRAMP authorization or an annual SSAE 18 SOC 2 Type II audit based on State required NIST Special Publication 800-53 MOD Controls; ~~using identified controls and minimum values as established in applicable State PSPs~~;

5.3 ensure that the Software and State Data is securely stored, hosted, supported, administered, Accessed, and backed up in the United States or its territories. The use of Offshore Resources is not permitted;

5.5 ensure the data center(s) in which Software and State Data resides minimally meets Uptime Institute Tier 3 standards (<https://www.uptimeinstitute.com/>), or its equivalent;

5.6 maintain and enforce an information security program including safety and physical and technical security policies and procedures with respect to its Processing of the State Data that complies with the requirements ~~identified in the Contractor's product-specific and/or service-specific documentation at the time use of product or services was first initiated of the State's data security policies as set forth in this Contract~~, and must, at a minimum, remain compliant with FISMA and NIST Special Publication 800-53 MOD Controls ~~using identified controls and minimum values as established in applicable State PSPs~~;

5.7 ~~As of the date of execution throughout the Term~~, Contractor ~~must~~ does not provide any part of the Solution from the list of excluded parties in the [System for Award Management \(SAM\)](#) for entities excluded from receiving federal government awards for "covered telecommunications equipment or services."

5.8 provide technical and organizational safeguards against accidental, unlawful or unauthorized access to or use, destruction, loss, alteration, disclosure, encryption, transfer, commingling or processing of such information that ensure a level of security appropriate to the risks presented by the Processing of State Data and the nature of such State Data, consistent with ~~best industry standards practice~~ and applicable standards ~~or requirements~~ (including, but not limited to, compliance with FISMA, NIST, CMS, IRS, FBI, SSA, HIPAA, FERPA and PCI requirements as applicable);

5.9 take all reasonable measures ~~consistent with the Contractor's product-specific and/or service-specific documentation~~ to:

Commented [JB2]: Oracle: Oracle understands this section to apply to Professional Services (or Implementation services) based on our interpretation of "access to the State's IT environment".

Commented [JB3]: Oracle: We revised the terms so that they are accurate for Oracle IaaS and PaaS products generally available in the US Gov Cloud Data Center. Oracle also made changes to these terms consistent with what was done in the Google and AWS agreements.

(a) secure and defend all locations, equipment, systems and other materials and facilities employed in connection with the Solution against "malicious actors" and others who may seek, without authorization, to destroy, disrupt, damage, encrypt, modify, copy, access or otherwise use Hosted Services or the information found therein; and
 (b) prevent (i) the State and its Authorized Users from having access to the data of other customers or such other customer's users of the Solution; (ii) State Data from being commingled with or contaminated by the data of other customers or their users of the Solution; and (iii) unauthorized access to any of the State Data;

5.10 ensure that State Data is encrypted in transit and at rest using FIPS validated AES encryption modules and a key size of 128 bits or higher;

5.12 ensure the Hosted Services ~~are aligned with~~ implements NIST compliant multi-factor authentication for the State to configure privileged/administrative and other identified access.

5.13 Contractor must permanently sanitize or destroy the State's information, including State Data, from all media both digital and nondigital including backups ~~in alignment with~~ using National Security Agency ("NSA") and/or National Institute of Standards and Technology ("NIST") (NIST Guide for Media Sanitization 800-88) data sanitization methods ~~or as otherwise instructed by the State~~. Contractor must sanitize information system media, both digital and non-digital, prior to disposal, release out of its control, or release for reuse as specified above.

6. Security Accreditation Process. Throughout the Term, Contractor will provide reasonable cooperation to assist the State, at no additional cost, to obtain and maintain its authority to operate (ATO). Contractor will work with the State in good faith with its ~~Security Accreditation Process~~, which includes the development, completion and on-going maintenance of a system security plan (SSP) using the State's automated governance, risk and compliance (GRC) platform, which requires Contractor to submit evidence, upon request from the State, in order to validate Contractor's security controls within two weeks of the State's request. ~~On an annual basis on the or as otherwise required by the State such as for significant changes, re-assessment of the system's controls will be required to receive and maintain authority to operate (ATO). All identified risks will be addressed as provided in Contractor's product-specific and/or service-specific documentation and any such updates will not materially reduce the level of performance, functionality, security or availability of the Services during the Services Period of Your order. All identified risks from the SSP will be remediated through a Plan of Action and Milestones (POAM) process with remediation time frames and required evidence based on the risk level of the identified risk. For all findings associated with the Contractor's solution, at no additional cost, Contractor will be required to create or assist with the creation of State-approved POAMs, perform related remediation activities, and provide evidence of compliance. The State will make any decisions on acceptable risk. Contractor may request risk acceptance, supported by compensating controls, however only the State may formally accept risk. Failure to comply with this section will be deemed a material breach of the Contract.~~

7. Unauthorized Access.

Contractor does not access the State Systems through its Oracle IaaS and PaaS products generally available in the US Government Cloud Data Center.

Contractor may not access, and must not permit any access to, State Systems, in whole or in part, whether through the Hosted Services or otherwise, without the State's express prior written authorization. Such authorization may be revoked by the State in writing at any time in its sole discretion. Any access to State Systems must be solely in accordance with the Contract and this Schedule, and in no case exceed the scope of the State's authorization pursuant to this Section. All State-authorized connectivity or attempted connectivity to State Systems shall be only through the State's security gateways and firewalls and in compliance with the State's security policies set forth in the Contract as the same may be supplemented or amended by the State and provided to Contractor from time to time.

8. Security Audits

8.1 During the Term, Contractor will maintain complete and accurate records of its data protection practices, IT security controls, and the security logs relating to State Data, including but not limited to any backup, disaster recovery or other policies, practices or procedures relating to the State Data and any other information relevant to its compliance with this Contract subject to time restraints in Contractor's product-specific and/or service-specific documentation.

Commented [JB4]: Oracle: The revisions to this section are similar to the Google and AWS agreements. In addition, Oracle cannot follow specific customer-imposed remediation requirements as Oracle's products are off the shelf.

Commented [JB5]: Oracle: Based on our interpretation of "State systems," this provision does not apply to any IaaS and PaaS products and only applies to the provision Professional Services, which is why we qualified the language in this way. Cloud Services are hosted on Oracle-managed infrastructure so the State will be leveraging Oracle's systems and not its own.

Commented [JB6]: Oracle: Oracle provides customers with a detailed audit right in the Data Processing Agreement and refers the State to that section. If the State requires audit rights beyond the standard, those may be purchased Oracle's enhanced audit program.

8.2 ~~The State's audit rights are as described in Section 8 (Audit Rights and Assistance with Data Protection Impact Assessments) of the Data Processing Agreement. Without limiting any other audit rights of the State, the State has the right to review Contractor's data privacy and information security program prior to the commencement of Services and from time to time during the term of this Contract. The State, at its own expense, is entitled to perform, or to have performed, an audit of Contractor's data privacy and information security program. If the State chooses to perform an audit, Contractor will, make all such records, appropriate personnel and relevant materials available for inspection and audit by the State or an independent data security expert that is reasonably acceptable to Contractor, provided that the State: (i) gives Contractor at least 5 Business Days prior notice of any such audit; (ii) undertakes such audit no more than once per calendar year, except for good cause shown; and (iii) conducts or causes to be conducted such audit in a manner designed to minimize disruption of Contractor's normal business operations and that complies with the terms and conditions of all data confidentiality, ownership, privacy, security and restricted use provisions of the Contract. The State may, but is not obligated to, perform such security audits.~~

8.3 During the Term, Contractor will, when requested by the State, provide a copy of Contractor's and Hosting Provider's (if applicable) FedRAMP System Security Plan(s) ~~or SOC 2 Type 2 report(s) provided the State signs a necessary Nondisclosure Agreement for Oracle's Virtual Reading Room or SOC 2 Type 2 report(s) to the State within two weeks of the State's request.~~ The System Security Plan and SSAE audit reports will be recognized as Contractor's Confidential Information.

8.4 With respect to State Data, Contractor must implement any required safeguards as identified by the State or by any audit of Contractor's data privacy and information security program.

8.5 The State reserves the right, at its sole election, to immediately terminate this Contract or a Statement of Work without limitation and without liability if the State determines that Contractor fails or has failed to meet its obligations under this Section 8.

9. **Application Scanning.** Contractor performs scanning on Oracle provided IaaS and PaaS Services ~~and the provision below applies only to such scanning and does not apply to Oracle software.~~ During the Term, Contractor must, at its sole cost and expense, scan Oracle IaaS and PaaS services, all Contractor provided applications, and must analyze, remediate and validate all vulnerabilities identified by the scans as required by FedRAMP and DISA the State Web Application Security Standard and other applicable PSPs.

Contractor's application scanning ~~and remediation~~ must include each of the following types of scans and activities:

9.1 Dynamic Application Security Testing (DAST) – Authenticated interactive scanning of application for vulnerabilities, analysis, remediation, and validation (may include Interactive Application Security Testing (IAST).

(b) Contractor must dynamically scan a deployed version of the Software using a State approved application scanning tool, and, upon request, provide the State with verification of the scanning and remediation after Contractor has completed such scan. These scans and assessments

(i) must be completed monthly or quarterly (as required dates to be provided by FedRAMP and DISA the State) and for each major release; 9.2 Static Application Security Testing (SAST) – Scanning source code for vulnerabilities, analysis, remediation, and validation.

(a) For Contractor provided applications, Contractor, at its sole expense, must provide resources to complete static application source code scanning, including the analysis, remediation and validation of vulnerabilities identified by application source code scans. These scans must be completed for all source code initially, for all updated source code, and for all source code for each major release and Contractor must, upon request, provide the State with verification of the scanning and remediation after Contractor has completed the required scans.

9.3 Software Composition Analysis (SCA) – Third-Party and/or Open Source Scanning for vulnerabilities, analysis, remediation, and validation.

(a) For Software that includes third-party and open source software, all included third-party and open source software must be documented and the source supplier must be

Commented [JB7]: Oracle: We provided more detail here about how customers can obtain this documentation.

Commented [JB8]: Oracle: Oracle performs scanning only on OCI IaaS and PaaS and not in the customer tenancy so we added language making that clear. Oracle also cannot remediate pursuant to customer specifications as the hosting and delivery of cloud services is not customizable.

monitored by the Contractor for notification of identified vulnerabilities and remediation. SCA scans may be included as part of SAST and DAST scanning or employ the use of an SCA tool to meet the scanning requirements. These scans must be completed for all third-party and open source software initially, for all updated third-party and open source software, and for all third party and open source software in each major release and Contractor must, upon request, provide the State with a validation that the Contractor has completed the required scans if not provided as part of SAST and/or DAST reporting.

9.4 In addition, application scanning and remediation may include the following types of scans and activities if required by regulatory or industry requirements, data classification or otherwise identified in the Contractor's product-specific and/or service-specific documentation by the State.

(a) If provided as part of the Cloud Services solution, all native mobile application software must meet these scanning requirements including any interaction with an application programming interface (API).

(b) Penetration Testing – Simulated attack on the application and infrastructure to identify security weaknesses.

10. Infrastructure Scanning.

10.1 Contractor must ensure their infrastructure and applications are scanned using an approved scanning tool (Qualys, Tenable, or other PCI Approved Vulnerability Scanning Tool) at least monthly and provide, upon request, validation of the scanning and remediation to the State in a format prescribed by FedRAMP and DISA that is specified by the State. Contractor will ensure the remediation of issues identified in the scan according to the remediation time requirements prescribed by FedRAMP and DISA in accordance with our FedRAMP High and DISA IL5 authorizations as outlined by NIST800-53 documented in the State's PSPs.

11. Nonexclusive Remedy for Security Breach.

11.1 Any failure of the Solution to meet the applicable requirements of this Schedule with respect to the security of any State Data or other Confidential Information of the State, including any related backup, disaster recovery or other policies, practices or procedures, is a material breach of the Contract for which the State, at its option, may terminate the Contract pursuant to the termination provisions in the Contract [CSA Section 9] immediately upon written notice to Contractor without any notice or cure period, and Contractor must promptly reimburse to the State any Fees prepaid by the State prorated to the date of such termination.

SCHEDULE E, ATTACHMENT B

The parties agree that, if the State determines that State or federal rules or regulations require the appendage of the specific contractual language contained in this attachment, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

Commented [JB9]: Oracle: Oracle takes exception to the Schedule E attachments and addenda as Oracle has an expansive portfolio of products and services and we cannot evaluate and accept detailed terms without knowing what is being purchased.

SAFEGUARD REQUIREMENTS OF CONFIDENTIAL TAX DATA

This section sets forth the safeguard requirements for handling, storage, and processing of confidential tax information for a Contractor and their subcontractor(s) and is incorporated as an integral part of the Contract. It will facilitate administration and enforcement of the laws of the State of Michigan in a manner consistent with the applicable statutes, regulations, published rules and procedures or written communication.

I. Authority

Authority for the Michigan Department of Treasury to require that this section be included in the Contract is contained in 1941 PA 122, as amended, MCL 205.28(1)(f), which subjects current or former contractors to the same restrictions and penalties imposed upon department employees regarding the treatment of confidential information. A private contractor or its employees are strictly prohibited from disclosing taxpayer information to a third party. The prohibition against disclosure does not bar an employee of a private contractor with whom the State of Michigan (State) contracts that processes tax returns or payments pursuant to the Contract from having access to confidential information that is reasonably required for the processing or collection of amounts due this State. Private contractors and any subcontractors will follow Treasury guidelines for Authorized representatives.

II. Confidentiality

It is agreed that all information exchanged under this section will be kept confidential in accordance with the confidentiality provisions contained in the Revenue Act, MCL 205.28(1)(f) which states in part;

“Except as otherwise provided in this subdivision, an employee, authorized representative, or former employee or authorized representative of the department or anyone connected with the department will not divulge any facts or information obtained in connection with the administration of a tax or information or parameters that would enable a person to ascertain the audit selection or processing criteria of the department for a tax administered by the department.”

Confidential information obtained under this contract will not be disclosed except as required by state law, or in the proper administration of applicable laws, promulgated rules and procedures. In the event, confidentiality statutes are amended, Treasury will notify Contractor of any changes. No employee, agent, authorized representative or legal representative of Contractor will disclose any information obtained by virtue of this section to any other division within their company or any other governmental agency, department or unit within such governmental agency whether

local, state, federal or foreign, department or unit within such governmental agency, or any unauthorized third party. No tax returns or tax return information accessed by Contractor will be duplicated or disseminated within or outside the company without the written approval of the Contract Compliance Inspector. Tax returns and tax return information remain the property of Treasury.

Contractor may use a taxpayer's name, address and Social Security number or employer identification number to the extent necessary in connection with the processing and mailing of forms for any report or return required in the administration of any tax in the performance of the Contract. The use of the Social Security number must be in accordance with the state Social Security Number Privacy Act 454 of 2004, as amended.

Confidential information obtained under this agreement will not be disclosed in part of a report or document that is subject to FOIA.

The penalties for violating the confidentiality provisions of the Revenue Act are contained in, MCL 205.28(2) and MCL 205.27(4). MCL 205.28(2) states:

"A person who violates subsection (1)(e), (1)(f), (4) or (5) is guilty of a felony, punishable by a fine of not more than \$5,000.00, or imprisonment for not more than 5 years, or both, together with the costs of prosecution. In addition, if the offense is committed by an employee of this state, the person will be dismissed from office or discharged from employment upon conviction."

MCL 205.27(4) states:

A person who is not in violation pursuant to subsection (2), but who knowingly violates any other provision of this act, or of any statute administered under this act, is guilty of a misdemeanor, punishable by a fine of not more than \$1,000.00, or imprisonment for not more than 1 year, or both.

Information received by Treasury from the U.S. Internal Revenue Service, pursuant to section 6103(d) of the Internal Revenue Code or any other federal agency will not be subject to the exchange.

III. Procedure for Security

Contractor will safeguard any tax return information obtained under the Contract as follows:

- A. Access to the tax returns and tax return information will be allowed only to those authorized employees and officials of Contractor who need the information to perform their official duties in connection with the uses of the information authorized in this Contract.
- B. Any records created from tax returns and tax return information will be stored in an area that is physically safe from access by unauthorized persons during duty hours and locked in a secure area during non-duty hours, or when not in use.
- C. Any records matched and any records created by the match will be processed under the immediate supervision and control of authorized personnel in a manner in which will protect the confidentiality of the records, and in such a way that unauthorized persons cannot retrieve any such records by means of a computer, remote terminal or other means.
- D. All personnel who will have access to the tax returns and tax return information and to any records created by the tax return information will be advised annually of the confidential nature of the information, the safeguards required to protect the information and the civil and criminal sanctions for noncompliance contained in MCL 205.28 (2) and MCL 205.27(4) and will sign confidentiality certifications.

E. All confidential information, electronic and paper, will be secured from unauthorized access and with access limited to designated personnel only. State tax return information will not be commingled with other information. All Michigan tax returns and return information will be marked as follows: **CONFIDENTIAL - DO NOT DISCLOSE - MICHIGAN TREASURY TAX RETURN INFORMATION**

F. Treasury, Office of Privacy and Security or Contract Compliance Inspector may make onsite inspections or make other provisions to ensure that adequate safeguards are being maintained by the Contractor.

G. The Treasury Office of Privacy and Security may monitor compliance of systems security requirements during the lifetime of the Contract or any extension.

H. Contractor will also adopt policies and procedures to ensure that information contained in their respective records and obtained from Treasury and taxpayers will be used solely as stipulated in the Contract.

IV. Computer System Security of Tax Data

The identification of confidential tax records and defining security controls are intended to protect Treasury tax return information from unlawful disclosure, modification, destruction of information and unauthorized secondary uses.

Computer system security and physical security of tax data stored and processed by Contractor must be in compliance with the following security guidelines and standards established by Treasury. These guidelines apply to any computer system developed by Contractor, either through its own systems staff, or through a contractor, subcontractor or vendor):

A. Controlled Access Protection

All computer systems processing, storing and transmitting Michigan tax information must have computer access protection controls. These security standards are delineated in the National Institute of Standards and Technology (NIST) Special Publications number 800-53 "Recommended Security Controls for the Federal Information Systems" at <http://csrc.nist.gov/publications/PubsSPs.html>. To meet these standards, the operating security features of the system must have the following minimum requirements: a security policy, accountability, assurance, and documentation.

1. **Security Policy** – A security policy is a written document describing the system in terms of categories of data processed, users allowed access and access rules between the users and the data. Additionally, it describes procedures to prevent unauthorized access by clearing all protected information on objects before they are allocated or reallocated out of or into the system. Further protection must be provided where the computer system contains information for more than one program/project, office, or Agency and that personnel do not have authorization to see all information on the system.

2. **Accountability** – Computer systems processing Michigan tax information must be secured from unauthorized access. All security features must be available (audit trails, identification and authentication) and activated to prevent unauthorized users from indiscriminately accessing Michigan tax information. Everyone who accesses computer systems containing Michigan tax information is accountable. Access controls must be maintained to ensure that unauthorized access does not go undetected. Computer programmers and contractors who have a need to access databases, and are

authorized under the law, must be held accountable for the work performed on the system. The use of passwords and access control measures must be in place to identify who accessed protected information and limit that access to persons with a need to know.

a) On-line Access –Users will be limited to any Treasury on-line functions, by limiting access through functional processing controls and organization restrictions.

Any employee granted access privileges through the Contractor’s Security Administrator will be approved for access and viewing rights to Treasury on-line systems by the Department of Treasury, Office of Privacy and Security.

b) Operating Features of System Security

Contractor must meet the following levels of protection with respect to tax return information. Individual user accountability must be ensured through user identification number and password.

- i. Access rights to confidential tax information must be secured through appropriate levels of authorization.
- ii. An audit trail must be maintained of accesses made to confidential information.
- iii. All confidential and protected information must be cleared from a system before it is used for other purposes not related to the enforcement, collection or exchange of data not covered by this section or by an addendum to this Contract.
- iv. Hard copies made of confidential tax return information must be labeled as confidential information.
- v. Confidential Treasury tax information will be blocked or coded as confidential on system.
- vi. Any computer system in which Michigan tax return information resides must systematically notify all users upon log-in of the following disclosure penalties for improperly accessing or making an authorized disclosure of Michigan tax return information:

NOTICE TO EMPLOYEES AND AUTHORIZED REPRESENTATIVES

This system contains Michigan Department of Treasury tax return information. **DO NOT DISCLOSE OR DISCUSS MICHIGAN RELATED TAX RETURN INFORMATION** with unauthorized individuals. The Revenue Act at MCL 205.28(1)(f) prohibits such disclosure.

MICHIGAN PENALTIES

A person making a willful unauthorized disclosure or inspection (browsing) of tax return information may be charged with the following Michigan penalties:

- Criminal penalties up to \$5,000 and/or imprisonment for 5 years, plus costs and dismissal from employment if it is found that a current or former employee or authorized representative has made an unauthorized disclosure of a tax return or tax return information or divulged audit selection or processing parameters. [MCL 205.28(2)]
- A misdemeanor, punishable by a fine of not more than \$1,000.00, or imprisonment for not more than 1 year, or both if the person is not in

violation pursuant to MCL 205.27(2), but who knowingly violates any other provision of this act, or of any statute administered under this act.

This statement is subject to modification. A confidentiality statement, subject to modification, will be sent as needed by the Security Administrator to all employees, contractors, and legal representatives of Contractor.

3. **Assurance** – Contractor must ensure that all access controls and other security features are implemented and are working when installed on their computer system. Significant enhancements or other changes to a security system must follow the process of review, independent testing, and installation assurance. The security system must be tested at least annually to assure it is functioning correctly. All anomalies must be corrected immediately.

a. The Contractor must initiate corrective action for all non-conformities as soon as detected and immediately advise the Contract Compliance Inspector. Notice of the corrective action must be provided to the Contract Compliance Inspector. All non-conformities must be reported to the Contract Compliance Inspector with the following:

- a. Duration of non-conformity/interruption
- b. Reason for non-conformity/interruption
- c. Resolution.

b. All non-conformities to the specifications/tasks of the Contract must be corrected within four (4) hours. The State recognizes there will be instances when adherence to this time frame will not be possible. However, the State will only tolerate this on an exception basis. To request an exception to this time frame, the Contractor must submit a detailed project plan to address the non-conformity within four (4) hours to the Contract Compliance Inspector for approval.

4. **Documentation** – Design and test documentation must be readily available to the state. The developer or manufacturer should initially explain the security mechanisms, how they are implemented and their adequacy (limitations). This information should be passed on to the security officer or supervisor. Test documentation should describe how and what mechanisms were tested and the results. If recognized organizations/tests/standards are used, then a document to that effect will suffice. For example, a system that has been tested and certified as meeting certain criteria may have a document stating this fact, without detailed tests/results of information. Contractor, however, must ensure the documentation covers the exact system and that it includes the specific computer system used by Contractor.

Additionally, documentation must include a security administrator's guide. The security administrator's guide is addressed to the System's Administrator and Security Officer and will describe the protection mechanisms provided by the security system, guidelines on their use and how they interact. This document will present cautions about security functions and describe privileges that should be controlled when running a secure system. The document will be secured and locked at all times with access rights only by the Systems Administrator and Security Officer.

Note: When a security system is designed or purchased for a specific computer or computer system, the security mechanisms must be reviewed by the State to ensure that needed security

parameters are met. An independent test should be implemented on the specific computer or computer system to ensure that the security system meets the security parameters within this contract and developed with the computer system. The test may be arranged by the developer but must be done by an independent organization. Contractor must assign responsible individuals (Security Officers) with knowledge of information technology and applications to oversee the testing process. These individuals must be familiar with technical controls used to protect the system from unauthorized entry.

Finally, contingency and backup plans must be in place to ensure protection of Michigan tax information.

V. Electronic Transmission of Michigan Tax Information

The two acceptable methods of transmitting Michigan tax information over telecommunications devices are encryption and using guided media. Encryption involves altering data objects in a way that the objects become unreadable until deciphered with the appropriate software at the intended destination. Guided media involves transmission of data over twisted pair cable, coaxial cable or end to end fiber optics which are typically used in secure computer networks like the state's Local Area Network (LAN), telephone systems, and television distribution.

Cryptography standards have been adopted by the IRS and can be used to provide guidance for encryption, message authentication codes or digital signatures and digital signatures with or without an associated certification infrastructure. For further information, see IRS Publication 1075 at the IRS web site.

Unencrypted cable circuits of fiber optics are an acceptable alternative for transmitting Michigan tax information. Adequate measures must be taken to ensure that circuits are maintained on cable and not converted to unencrypted radio or microwave transmission. Additional precautions should be taken to protect the cable, i.e., burying the cable underground or in walls or floors and providing access controls to cable vaults, rooms and switching centers.

A. Remote Access

Accessing databases containing Michigan tax information from a remote location – that is, a location not directly connected to the Local Area Network (LAN) will require adequate safeguards to prevent unauthorized entry.

For remote access, the contractor is required to use an identification security card that requires both PIN and card in possession. The State identified and approved methods for remote vendor access are as follows:

- SecureID through VPN – State provided SecureID taken and VPN software in order to access State of Michigan resources. Appropriate Acceptable Use policies and signoffs are required
- Follow-the Sun SecureID – Vendor is provided with VPN software and a SOM technical resource coordinates with the DTMB Client Service Center to provide secure ID code access to specific State of Michigan resources. Appropriate Acceptable Use Policies and signoffs are required.

B. Portable Computer Devices

Any entrusted confidential information collected or accessed during this Contract must be encrypted when stored on all storage devices and media. This includes, but not limited to, disk drives for servers and workstations, and portable memory media (PDAs, RAM drives, memory sticks, etc.).

VI. Record Keeping Requirements for Information Received

Each Contractor, requesting and receiving information will keep an accurate accounting of the information received. The audit trail will be required which will include the following information:

- a. Taxpayer's name
- b. Identification number
- c. Information requested
- d. Purpose of disclosure request
- e. Date information received
- f. Name of Division and employee making request
- g. Name of other employees who may have had access
- h. Date destroyed
- i. Method of destruction

The Contractor will adopt and implement formal procedures to:

- Ensure proper handling of tax returns and tax return information;
- Secure and safeguard information from unauthorized use; and
- Ensure appropriate destruction of information and materials retrieved from Treasury.

A. Electronic Media

Contractor will keep an inventory of magnetic and electronic media received under the Contract.

Contractor must ensure that the removal of tapes and disks and paper documents containing Michigan tax return information from any storage area is properly recorded on charge-out records. Contractor is accountable for missing tapes, disks, and paper documents.

B. Recordkeeping Requirements of Disclosure Made to State Auditors

When disclosures are made by Contractor to State Auditors, these requirements pertain only in instances where the Auditor General's staff extracts Michigan tax returns or tax information for further review and inclusion in their work papers. Contractor must identify the hard copies of tax records or if the tax information is provided by magnetic tape format or through other electronic means, the identification will contain the approximate number of taxpayer's records, the date of inspection, the best possible description of the records and the name of the Auditor(s) making the inspection.

The Disclosure Officer must be notified, in writing, of any audits done by auditors, internal or otherwise, of Contractor that would involve review of Treasury processing parameters.

VII. Contract Services

To the extent the Contractor employs an independent agency, consultant, or agent to process confidential information which includes Michigan tax return information; the Contractor will notify the Treasury Disclosure Officer before the execution of any such agreement. Each agreement will include in the agreement the following recommended safeguard provisions:

- A. The identification of confidential tax records and defining security controls are intended to protect Treasury tax return information from unlawful disclosure, modification, destruction of information and unauthorized secondary uses.

Definition of Treasury Tax Return Information as defined in Revenue Administrative Bulletin (RAB) 1989-39:

B. Taxpayer's identity, address, the source or amount of his/her income, payments, receipts, deductions, exemptions, credits, assets, liabilities, net worth, tax liability, tax withheld, deficiencies, over assessments, or tax payments whether the taxpayer's return was, is being or will be examined or subject to their investigation or processing, or any other data, received by, recorded by, prepared by, furnished to or collected by the agency with respect to a return or with respect to the determination of the existence, or liability (or the amount thereof) of any person under the tax laws administered by the Department, or related statutes of the state for any tax, penalty, interest, fine, forfeiture, or other imposition or offense. The term "tax return information" also includes any and all account numbers assigned for identification purposes.

B. An acknowledgment that a taxpayer has filed a return is known as a "fact of filing" and may not be disclosed. All tax return data made available in any format will be used only for the purpose of carrying out the provisions of the Contract between Contractor and the sub-contractor. Information contained in such material will be treated as confidential and will not be divulged or made known in any manner to any person except as may be necessary in the performance of the Contract between Contractor and the subcontractor. In addition, all related output will be given the same level of protection as required for the source material.

C. The subcontractor will certify that the data processed during the performance of the Contract between Contractor and the subcontractor will be completely purged from all data storage components of the subcontractor's computer facility, and no output will be retained by the subcontractor at the time the work is completed.

D. Destruction of tax data, including any spoilage or any intermediate hard copy printout which may result during the processing of Michigan tax return information, will be documented with a statement containing the date of destruction, description of material destroyed, and the method used. Destruction parameters must meet the standards of Section IX, Disposal of Tax Information, of this agreement.

E. Computer system security and physical security of tax data stored and processed by the subcontractor must be in compliance with security guidelines and standards established by this contract. See section VI (Record Keeping Requirements for Information Received in Paper Format) for more details.

F. The Contractor will be responsible for maintaining a list of employees authorized to access Michigan tax return information and will provide a copy of such list to Treasury.

G. No work involving information furnished under the contract will be subcontracted without the specific approval of Treasury. Contractor and approved subcontractors handling Michigan tax return information will be required to sign the *Vendor, Contractor or Subcontractor Confidentiality Agreement* provided by Treasury, (Form 3337, see Attachment A). The original agreements will be returned to the Disclosure Officer for the Department of Treasury and a copy sent to the Contract Compliance Inspector.

VIII. Transport of Tax Information

In the event, it is necessary to transport confidential tax return information the Contractor is responsible for holding the carrier responsible for safeguarding the records. The Contractor must obtain a signed *Vendor, Contractor or Subcontractor Confidentiality Agreement* (Form 3337, see

Attachment A) for each carrier employee who has access to Michigan tax return information. The original agreements will be returned to the Department of Treasury, Disclosure Officer and a copy sent to the Contract Compliance Inspector.

If it is necessary to transfer records and responsibility for transport to a third carrier due to a mishap during transportation, the Contractor is responsible for ensuring safeguard standards remain enforce. This type of incident will be documented in accordance with the incident reporting guidelines in procedure PT-03253, "Incident Reporting and Handling".

Any such incidents must be reported to the Contract Administrator immediately.

IX. Disposal of Tax Information

Materials furnished to Contractor, such as tax returns, remittance vouchers, W-2 reports, correspondence, computer printouts, carbon paper, notes, memorandums and work papers will be destroyed by burning, mulching, pulverizing or shredding. If shredded, destroy paper using cross cut shredders which produce particles that are 1 mm x 5mm (0.04in x 0.2 in.) in size (or smaller). Data tracks should be overwritten or reformatted a minimum of three times or running a magnetic strip over entire area of disk at least three (3) times to remove or destroy data on the disk media. Electronic data residing on any computer systems must be purged based on Treasury's retention schedule.

Contractor and its subcontractor(s) will retain all confidential tax information received by Treasury only for the period of time required for any processing relating to the official duties and then will destroy the records. Any confidential tax information that must be kept to meet evidentiary requirements must be kept in a secured, locked area and properly labeled as confidential return information. See Procedure for Security (Section III of this agreement) for more details.

X. Security Responsibility

Contractor will designate a security person who will ensure that each individual having access to confidential tax information or to any system which processes Michigan tax return information is appropriately screened, trained and executes a *Vendor, Contractor or Subcontractor Confidentiality Agreement* (Form 3337, see Attachment A) before gaining access or transaction rights to any process and computer system containing Treasury tax return information.

Each Contractor or their subcontractor(s) employees' access and transaction rights will be reviewed periodically to ensure that there is a need to know Treasury tax return information displayed in any media.

Michigan tax return information will be made available only to individuals authorized by the Contract. Contractor will maintain a list of persons authorized to request and receive information and will update the list as necessary. A copy of the list must be furnished to the Michigan Department of Treasury Disclosure Officer and Contract Compliance Inspector.

XI. Security Breach Notification

The Contractor is required to report to Treasury, on Form 4000, Incident Reporting (Attachment B) any use or disclosure of confidential information, whether suspected or actual, **immediately** after becoming aware of the misuse or disclosure. The Contractor may substitute its internal form for Form 4000 if all pertinent information is included.

The Contractor agrees to immediately contain the breach if it is determined ongoing.

Treasury has the right to terminate the Contract when a breach has occurred, and the Contractor cannot demonstrate proper safeguards were in place to avert a breach. Treasury must approve Contractor's resolution to the breach.

XIII. Certification of Compliance

The Contractor will fully protect State Tax Information (STI) entrusted to them. Each Contractor or subcontractor who will have access to STI must read and sign a confidentiality agreement. This contract requires that all information obtained from the Michigan Department of Treasury under the Revenue Act, PA 122 of 1941, MCL 205.28 (1)(f) be kept confidential. In the event of a security breach involving STI in the possession of the Contractor, the Contractor agrees to provide full cooperation to conduct a thorough security review. The review will validate compliancy with the Contract, and state laws and regulations.

If, as a result of the Contractor's failure to perform as agreed, the State is challenged by a governmental authority or third party as to its conformity to or compliance with State, Federal and local statutes, regulations, ordinances or instructions; the Contractor will be liable for the cost associated with loss of conformity or compliance.

The Contractor understands the cost reflects violation fines identified by the Michigan Social Security Number Privacy Act, 454 of 2004 and the Michigan Identity Theft Protection Act, Act 452 of 2004 as amended.

XI. Effective Date

These Safeguard requirements will be reviewed whenever the Contract modifications include specifications or processes that affect tax data.

Reset Form

Michigan Department of Treasury
3337 (Rev. 10-16)

Vendor, Contractor or Subcontractor Confidentiality Agreement

The Revenue Act, Public Act 122 of 1941, MCL 205.28(1)(f), the City Income Tax Act, Public Act 284 of 1964, MCL 141.674(1), and Internal Revenue Code (IRC) 6103(d), make all information acquired in administering taxes confidential. The Acts and IRC hold a vendor, contractor or subcontractor and their employees who sell a product or provide a service to the Michigan Department of Treasury, or who access Treasury data, to the strict confidentiality provisions of the Acts and IRC. Confidential tax information includes, but is not limited to, information obtained in connection with the administration of a tax or information or parameters that would enable a person to ascertain the audit selection or processing criteria of the Michigan Department of Treasury for a tax administered by the department.

INSTRUCTIONS. Read this entire form before you sign it. If you do not complete this agreement, you will be denied access to Michigan Department of Treasury and federal tax information. After you and your witness sign and date this form, keep a copy for your records. Send the original to the address listed below.

Company Name and Address (Street or R/R, City, State, ZIP Code)		Last Name	First Name
		Driver License Number/Passport Number	Telephone Number
State of Michigan Department	Division	Subcontractor Name, if Product/Service furnished to Contractor	
Describe here or in a separate attachment the product or service being provided to the State of Michigan Agency (Required).			

Confidentiality Provisions. It is illegal to reveal or browse, except as authorized:

- All tax return information obtained in connection with the administration of a tax. This includes information from a tax return or audit and any information about the selection of a return for audit, assessment or collection, or parameters or tolerances for processing returns.
- All Michigan Department of Treasury or federal tax returns or tax return information made available, including information marked "Official Use Only". Tax returns or tax return information shall not be divulged or made known in any manner to any person except as may be needed to perform official duties. Access to Treasury or federal tax information, in paper or electronic form, is allowed on a need-to-know basis only. Before you disclose returns or return information to other employees in your organization, they must be authorized by Michigan Department of Treasury to receive the information to perform their official duties.
- Confidential information shall not be disclosed by a department employee to confirm information made public by another party or source which is part of any public record. 1999 AC, R 2005.1004(1).

Violating confidentiality laws is a felony, with penalties as described:

Michigan Penalties

MCL 205.28(1)(f) provides that you may not willfully disclose or browse any Michigan tax return or information contained in a return. Browsing is defined as examining a return or return information acquired without authorization and without a need to know the information to perform official duties. Violators are guilty of a felony and subject to fines of \$5,000 or imprisonment for five years, or both. State employees will be discharged from state service upon conviction.

Any person who violates any other provision of the Revenue Act, MCL 205.1, et seq., or any statute administered under the Revenue Act, will be guilty of a misdemeanor and fined \$1,000 or imprisonment for one year, or both, MCL 205.27(4).

City Penalties

MCL 141.674(2) provides that any person divulging confidential City Tax information is guilty of a misdemeanor and subject to a fine not exceeding \$500 or imprisonment for a period not exceeding 90 days, or both, for each offense.

Federal Penalties

If you willfully disclose federal tax returns or tax return information to a third party, you are guilty of a felony with a fine of \$5,000 or imprisonment for five years, or both, plus prosecution costs according to the Internal Revenue Code (IRC) §7213, 26 USC 7213.

In addition, inspecting, browsing or looking at a federal tax return or tax return information without authorization is a felony violation of IRC §7213A, subjecting the violator to a \$1,000 fine or imprisonment for one year, or both, plus prosecution costs. Taxpayers affected by violations of §7213A must be notified by the government and may bring a civil action against the federal government and the violator within two years of the violation. Civil damages are the greater of \$1,000 or actual damages incurred by the taxpayer, plus the costs associated with bringing the action, 26 USC 7431.

Failure to comply with this confidentiality agreement may jeopardize your employer's contract with the Michigan Department of Treasury.

Certification		
By signing this Agreement, I certify that I have read the above confidentiality provisions and understand that failure to comply is a felony.		
Print name of employee signing this agreement	Signature of person named above	Date signed
Print Witness Name (Required)	Signature of Witness (Required)	Date signed

Submit your form to the following address:

Office of Privacy and Security/ Disclosure Unit
Michigan Department of Treasury
430 W. Allegan Street
Lansing, MI 48922

Questions, contact the Office of Privacy and Security by telephone, 517-636-4239; fax, 517-636-5340; or email:

Treas_Disclosure@michigan.gov

Michigan Department of Treasury
 4000 (Rev. 05-14)

Reset Form

Incident Report

INSTRUCTIONS: Complete Parts 1 and 2 and immediately submit Initial Report to the Office of Privacy and Security. After incident resolution, submit Final Report (Parts 1, 2 and 3) to the Office of Privacy and Security. Refer to Procedure PT-03253, Incident Reporting and Handling.

PART 1: A. CONTACT INFORMATION (Reporting Entity)			
Full Name (Last, First, Middle Initial)		Division/Office	
Telephone Number	Fax Number	E-Mail Address	
B. CONTACT INFORMATION (Affected Entity)			
Full Name (Last, First, Middle Initial)		Division/Office	
Telephone Number	Fax Number	E-Mail Address	
PART 2: INCIDENT INFORMATION			
Whose information was involved in the incident?			
☐ Treasury ☐ Federal Tax Information ☐ Other State Agency, specify _____ ☐ Other _____			
Incident Category (select all that apply)			
☐ Passwords Shared/Stolen ☐ Computer Virus/Spam ☐ Paper Archives Compromised ☐ Misrouted Communications ☐ Data Destruction/Deletion ☐ Safe/Lockbox/Other Compromise ☐ Unauthorized Access ☐ Backups Missing or Stolen ☐ Delivery of Documents Lost ☐ Fraudulent Actions ☐ Hacking of Networks/Systems ☐ Inappropriate Destruction Paper ☐ Lost/Stolen Information/Data ☐ Improperly Secured Sys/Web ☐ Inappropriate Destruction Media ☐ Lost/Stolen Cash/Checks ☐ Circumvention of Security Protocols ☐ Lost/Stolen Equipment ☐ Inappropriate Building Access ☐ _____ ☐ _____			
Incident Affects			
☐ Financial Information/Resources ☐ Personal Information (SSN, Driver License No, Financial Information) ☐ Unauthorized/Unlawful Activity ☐ Confidential/Sensitive Information ☐ Human Resources (threat) ☐ Other _____			
Date Incident Occurred	Time Incident Occurred	Date Incident Discovered	Time Incident Discovered
Incident Location		Number of Individuals Affected	
Involved Parties/Entities		Does this involve personal information (first and last name along with a SSN, driver license number, or credit/debit card account number)? ☐ Yes ☐ No	
Date of Initial Report			
Description of Incident			

4000, Page 2

PART 1: CONTACT INFORMATION (Affected Entity)			
Full Name (Last, First, Middle Initial)		Division/Office	
PART 3: INCIDENT RESOLUTION			
Notification issued to affected individuals? ☐ Yes ☐ No	How many notifications were sent?	Breach Notification Method? ☐ E-mail ☐ Telephone ☐ US Mail ☐ Web	
Who was notified?		Date notification was issued	
Incident Cost ☐ Check if incident costs are less than \$250. If \$250 or more, complete the detailed summary of costs below.			
Manhours:		Other:	
Treasury \$ _____		Postage \$ _____	
DTMB-QES \$ _____		Credit Monitoring Service \$ _____	
DTMB-Treasury Agency Services \$ _____		\$ _____	
		Total Cost of Incident \$ _____	
Action Taken:			
Incident Impact:			
Post Incident Recommendations:			
PART 4: REPORT PREPARER INFORMATION			
Final Report Prepared By:	Date Prepared	Preparer Title	Preparer's Telephone Number
Preparer Signature			Date
OFFICE OF PRIVACY AND SECURITY USE ONLY			
Administrator, Office of Privacy and Security Signature			Date

SCHEDULE E, Attachment 1 – PCI Compliance and CEPAS

The parties agree that, if the State determines that State or federal rules or regulations require the appendage of the specific contractual language contained in this attachment, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

1. PCI Compliance.

Contractors that process, transmit store or affect the security of credit/debit cardholder data, must adhere to the PCI Data Security Standard. The Contractor is responsible for the security of cardholder data in its possession. The data may only be used to assist the State or for other uses specifically authorized by law.

The Contractor must notify the State's Contract Administrator (within 48 hours of discovery) of any breaches in security where cardholder data has been compromised. In that event, the Contractor must provide full cooperation to the card associations (e.g. Visa, MasterCard, Discover, and American Express) and state acquirer representative(s), or a PCI approved third party, to conduct a thorough security review. The Contractor must provide, at the request of the State, the results of such third party security review. The review must validate compliance with the PCI Data Security Standard for protecting cardholder data. At the State's sole discretion, the State may perform its own security review, either by itself or through a PCI approved third party.

The Contractor is responsible for all costs incurred as the result of the breach. Costs may include, but are not limited to, fines/fees for non-compliance, card reissuance, credit monitoring, and any costs associated with a card association, PCI approved third party, or State initiated security review.

Without limiting Contractor's obligations of indemnification as further described in this Contract, Contractor must indemnify, defend, and hold harmless the State for any and all claims, including reasonable attorneys' fees, costs, and incidental expenses, which may be suffered by, accrued against, charged to, or recoverable from the State in connection with the breach.

The Contractor must dispose of cardholder data when it is no longer needed in compliance with PCI DSS policy. The Contractor must continue to treat cardholder data as confidential upon contract termination.

The Contractor must provide the State's Contract Administrator with an annual Attestation of Compliance (AOC) if or a Report on Compliance (ROC) showing the contractor is in compliance with the PCI Data Security Standard. The Contractor must notify the State's Contract Administrator of all failures to comply with the PCI Data Security Standard.

2. CEPAS Electronic Receipt Processing Standard.

All electronic commerce applications that allow for electronic receipt of credit or debit card and electronic check transactions must be processed via the State's Centralized Electronic Payment Authorization System (CEPAS). To minimize the risk to the State, full credit/debit card numbers, sensitive authentication data, and full bank account information must never be stored on state-owned IT resources. For additional information, refer to the CEPAS Integration Guide that can be found at:

<https://stateofmichigan.sharepoint.com/teams/insidetreasury/about-treasury/work-areas/Documents/CEPAS/Integration%20Guides%20and%20Hotfix%20Notes/PayPoint%20Merchant%20Integration%20Guide%202.14.2021.pdf?CT=1623169629598&OR=Outlook-Body&CID=97F008F1-D094-4ED7-9335-63E0B12988E6>

SCHEDULE E, Attachment C - HIPAA BUSINESS ASSOCIATE AGREEMENT

The parties agree that, if the State determines that State or federal rules or regulations require the appendage of the specific contractual language contained in this attachment, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

The parties to this Business Associate Agreement (“Agreement”) are the Michigan Department of Technology, Management and Budget (“DTMB”, “Business Associate 1”) on behalf of **[Insert Name of End-User Agency whose PHI is involved]** (“Covered Entity”) and **[Insert Name of Contractor who will be handling PHI]** “Business Associate 2”.

RECITALS

- A. Under this Agreement, Business Associate 2 will collect or receive certain information on the Covered Entity’s behalf, some of which may constitute Protected Health Information (“PHI”). In consideration of the receipt of PHI, the Business Associate agrees to protect the privacy and security of the information as set forth in this Agreement.
- B. Covered Entity and each Business Associate intend to protect the privacy and provide for the security of PHI collected or received by the Business Associate under the Agreement in compliance with the Health Insurance Portability and Accountability Act of 1996, Public Law 104-191 (“HIPAA”) and the HIPAA Rules, as amended.
- C. The HIPAA Rules require the Covered Entity to enter into an agreement containing specific requirements with Business Associate 1, and likewise Business Associate 1 must enter an agreement with Business Associate 2 before the Business Associate 2’s receipt of PHI.

AGREEMENT

1. Definitions.

- a. The following terms used in this Agreement have the same meaning as those terms in the HIPAA Rules: Breach; Data Aggregation; Designated Record Set; Disclosure; Health Care Obligations; Individual; Minimum Necessary; Notice of Privacy Practices; Protected Health Information; Required by Law; Secretary;

Security Incident; Security Measures, Subcontractor; Unsecured Protected Health Information, and Use.

b. “Business Associate” has the same meaning as the term “business associate” at 45 CFR 160.103 and regarding this Agreement means DTMB (“Business Associate 1”) and **[Insert Name of Contractor]** (“Business Associate 2”).

c. “Covered Entity” has the same meaning as the term “covered entity” at 45 CFR 160.103 and regarding this Agreement means the **[Insert Name of End-User Agency whose PHI is involved]**.

d. “HIPAA Rules” means the Privacy, Security, Breach Notification, and Enforcement Rules at 45 CFR Part 160 and Part 164.

2. Obligations of Business Associate 2.

Business Associate 2 agrees to:

a. use and disclose PHI only as permitted or required by this Agreement or as required by law.

b. implement and use appropriate safeguards and comply with Subpart C of 45 CFR 164 regarding electronic protected health information, to prevent use or disclosure of PHI other than as provided in this Agreement. Business Associate 2 must maintain, and provide a copy to the Covered Entity and Business Associate 1 within 10 days of a request from the Covered Entity or Business Associate 1, a comprehensive written information privacy and security program that includes security measures that reasonably and appropriately protect the confidentiality, integrity, and availability of PHI relative to the size and complexity of Business Associate 2’s operations and the nature and the scope of its activities.

c. report to the Covered Entity and Business Associate 1 within 24 hours of any use or disclosure of PHI not provided for by the Agreement of which it becomes aware, including breaches of Unsecured Protected Health Information as required by 45 CFR 164.410, and any Security Incident of which it becomes aware. If Business Associate 2 is responsible for any unauthorized use or disclosure of PHI, it must promptly act as required by applicable federal and State laws and regulations. Covered Entity and Business Associate 2 will cooperate in investigating whether a breach has occurred, to decide how to provide breach notifications to individuals, the federal Health and Human Services’ Office for Civil Rights, and potentially the media.

d. ensure, according to 45 CFR 164.502(e)(1)(ii) and 164.308(b)(2), if applicable, that any subcontractors that create, receive, maintain, or transmit PHI on behalf of Business Associate 2 agree to the same restrictions, conditions, and requirements that apply to Business Associate 2 regarding such information. Each subcontractor must sign an agreement with Business Associate 2 containing substantially the same provisions as this Agreement and further identifying Business Associate 1 and Covered Entity as a third-party beneficiary of the agreement with the subcontractor. Business Associate 2 must implement and

maintain sanctions against subcontractors that violate such restrictions and conditions and must mitigate the effects of any such violation.

e. make available PHI in a Designated Record Set to the Covered Entity within 10 days of a request from the Covered Entity to satisfy the Covered Entity's obligations under 45 CFR 164.524.

f. within ten days of a request from the Covered Entity, amend PHI in a Designated Record Set under, 45 CFR § 164.526. If any individual requests an amendment of PHI directly from Business Associate 2 or its agents or subcontractors, Business Associate 2 must notify the Covered Entity in writing within five days of the request and amend the information within ten days of the request. Any denial of amendment of PHI maintained by Business Associate 2 or its agents or subcontractors is the responsibility of Business Associate 2.

g. maintain, and within ten days of a request from the Covered Entity make available, the information required to provide an accounting of disclosures to enable the Covered Entity to fulfill its obligations under 45 CFR § 164.528. Business Associate 2 is not required to provide an accounting to the Covered Entity of disclosures: (i) to carry out treatment, payment or health care operations, as set forth in 45 CFR § 164.506; (ii) to individuals of PHI about them as set forth in 45 CFR § 164.502; (iii) under an authorization as provided in 45 CFR § 164.508; (iv) to persons involved in the individual's care or other notification purposes as set forth in 45 CFR § 164.510; (v) for national security or intelligence purposes as set forth in 45 CFR § 164.512(k)(2); (vi) to correctional institutions or law enforcement officials as set forth in 45 CFR § 164.512(k)(5); (vii) as part of a limited data set according to 45 CFR 164.514(e); or (viii) that occurred before the compliance date for the Covered Entity. Business Associate 2 agrees to implement a process that allows for an accounting to be collected and maintained by Business Associate 2 and its agents or subcontractors for at least six years before the request, but not before the compliance date of the Privacy Rule. At a minimum, such information must include: (i) the date of disclosure; (ii) the name of the entity or person who received PHI and, if known, the address of the entity or person; (iii) a brief description of PHI disclosed; and (iv) a brief statement of purpose of the disclosure that reasonably informs the individual of the basis for the disclosure or a copy of the written request for disclosure. If the request for an accounting is delivered directly to Business Associate 2 or its agents or subcontractors, Business Associate 2 must, within ten days of the receipt of the request, forward it to the Covered Entity in writing.

h. to the extent Business Associate 2 is to carry out one or more of the Covered Entity's obligations under Subpart E of 45 CFR Part 164, comply with the requirements of Subpart E that apply to the Covered Entity when performing those obligations.

i. make its internal practices, books, and records relating to Business Associate 2's use and disclosure of PHI available to the Secretary for purposes of determining compliance with the HIPAA Rules. Business Associate 2 must

concurrently provide to the Covered Entity a copy of any PHI that the Business Associate 2 provides to the Secretary.

j. retain all PHI throughout the term of the Agreement and for a period of six years from the date of creation or the date when it last was in effect, whichever is later, or as required by law. This obligation survives the termination of the Agreement.

k. implement policies and procedures for the final disposition of PHI and the hardware and equipment on which it is stored, including but not limited to, removal of PHI before re-use.

l. within ten days of a written request by the Covered Entity, Business Associate 2 and its agents or subcontractors must allow the Covered Entity to conduct a reasonable inspection of the facilities, systems, books, records, agreements, policies and procedures relating to the use or disclosure of PHI under this Agreement. Business Associate 2 and the Covered Entity will mutually agree in advance upon the scope, timing and location of such an inspection. Covered Entity must protect the confidentiality of all confidential and proprietary information of Business Associate 2 to which the Covered Entity has access during the course of such inspection. Covered Entity and Business Associate 2 will execute a nondisclosure agreement, if requested by the other party. The fact that the Covered Entity inspects, or fails to inspect, or has the right to inspect, Business Associate 2's facilities, systems, books, records, agreements, policies and procedures does not relieve Business Associate 2 of its responsibility to comply with this Agreement. Covered Entity's (i) failure to detect or (ii) detection, but failure to notify Associate or require Associate's remediation of any unsatisfactory practices, does not constitute acceptance of such practice or a waiver of the Covered Entity's enforcement rights under this Agreement.

3. Permitted Uses and Disclosures by the Business Associate.

a. Business Associate 2 may use or disclose PHI:

(1) for the proper management and administration of Business Associate 2 or to carry out the legal responsibilities of Business Associate 2; provided, however, either (A) the disclosures are required by law, or (B) Business Associate 2 obtains reasonable assurances from the person to whom the information is disclosed that the information will remain confidential and used or further disclosed only as required by law or for the purposes for which it was disclosed to the person, and the person notifies Business Associate 2 of any instances of which it is aware in which the confidentiality of the information has been breached;

(2) as required by law;

(3) for Data Aggregation services relating to the health care operations of the Covered Entity;

(4) to de-identify, consistent with 45 CFR 164.514(a) – (c), PHI it receives from the Covered Entity. If Business Associates 2 de-identifies the PHI it receives from the Covered Entity, Business Associate 2 may use the de-identified information for any purpose not prohibited by the HIPAA Rules; and

(5) for any other purpose listed here: **[describe how Business Associate 2 will use and/or disclose PHI under this Agreement].**

b. Business Associate 2 agrees to make uses and disclosures and requests for PHI consistent with the Covered Entity's minimum necessary policies and procedures.

c. Business Associate 2 may not use or disclose PHI in a manner that would violate Subpart E of 45 CFR Part 164 if done by the Covered Entity except for the specific uses and disclosures described above in 3(a)(i) and (iii).

4. Covered Entity's Obligations

Covered entity agrees to:

- a. use its Security Measures to reasonably and appropriately maintain and ensure the confidentiality, integrity, and availability of PHI transmitted to Business Associate 2 under this Agreement until the PHI is received by Business Associate 2.
- b. provide Business Associate 2 with a copy of its Notice of Privacy Practices and must notify the Business Associate of any limitations in the Notice of Privacy Practices of the Covered Entity under 45 CFR 164.520 to the extent that such limitation may affect Business Associate 2's use or disclosure of PHI.
- c. notify Business Associate 2 of any changes in, or revocation of, the permission by an individual to use or disclose the individual's PHI to the extent that such changes may affect Business Associate 2's use or disclosure of PHI.
- d. notify Business Associate 2 of any restriction on the use or disclosure of PHI that the Covered Entity has agreed to or is required to abide by under 45 CFR 164.522 to the extent that such restriction may affect Business Associate 2's use or disclosure of PHI.

5. Term. This Agreement continues in effect until terminated or is replaced with a new agreement between the parties containing provisions meeting the requirements of the HIPAA Rules, whichever first occurs.

6. Termination.

a. Material Breach. In addition to any other provisions in the Agreement regarding breach, a breach by Business Associate 2 of any provision of this Agreement, as determined by the Covered Entity, constitutes a material breach of the Agreement and provides grounds for Business Associate 1 to terminate this Agreement for cause at the request of Covered Entity. Termination for cause is subject to 6.b.:

(1) Default. If Business Associate 2 refuses or fails to timely perform any of the provisions of this Agreement, the Covered Entity may notify Business Associate 2 in writing of the non-performance, and if not corrected within thirty days, Business Associate 1 may immediately terminate the Agreement at the request of Covered Entity. The Business Associate 2 must continue performance of the Agreement to the extent it is not terminated.

(2) Business Associate 2's Duties. Notwithstanding termination of the Agreement, and subject to any directions from the Covered Entity or Business Associate 1, Business Associate 2 must protect and preserve property in the possession of Business Associate 2 in which the Covered Entity has an interest.

(3) Erroneous Termination for Default. If Business Associate 1 terminates this Agreement at the request of Covered Entity under Section 6(a) and after such termination it is determined, for any reason, that Business Associate 2 was not in default, then such termination will be treated as a termination for convenience, and the rights and obligations of the parties will be the same as if the Agreement had been terminated for convenience.

b. Reasonable Steps to Cure Breach. If the Covered Entity or Business Associate 1 knows of a pattern of activity or practice of Business Associate 2 that constitutes a material breach or violation of Business Associate 2's obligations under the provisions of this Agreement or another arrangement and does not terminate this Agreement under Section 6(a), then the Business Associate 1, at the request of Covered Entity or on its own accord, must notify Business Associate 2 of the pattern of activity or practice. Business Associate 2 must then take reasonable steps to cure such breach or end such violation, as applicable. If the Business Associate 2's efforts to cure such breach or end such violation are unsuccessful, Business Associate 1, at the request of the Covered Entity or on its own accord, may either (i) terminate this Agreement, if feasible or (ii) report Business Associate 2's breach or violation to the Secretary.

c. Effect of Termination. After termination of this Agreement for any reason, the Business Associate, with respect to PHI it received from the Covered Entity, or created, maintained, or received by Business Associate 2 on behalf of the Covered Entity, must:

(1) retain only that PHI which is necessary for Business Associate 2 to continue its proper management and administration or to carry out its legal responsibilities;

(2) return to the Covered Entity (or, if agreed to by the Covered Entity in writing, destroy) the remaining PHI that Business Associate 2 still maintains in any form;

(3) continue to use appropriate safeguards and comply with Subpart C of 45 CFR Part 164 with respect to electronic protected health information to prevent use or disclosure of the PHI, other than as provided for in this Section, for as long as Business Associate 2 retains the PHI;

(4) not use or disclose the PHI retained by Business Associate 2 other than for the purposes for which such PHI was retained and subject to the same conditions set out at Section 3(a)(1) which applied before termination; and

(5) return to the Covered Entity (or, if agreed to by the Covered Entity in writing, destroy) the PHI retained by Business Associate 2 when it is no longer needed by Business Associate 2 for its proper management and administration or to carry out its legal responsibilities.

7. **No Waiver of Immunity.** The parties do not intend to waive any of the immunities, rights, benefits, protection, or other provisions of the Michigan Governmental Immunity Act, MCL 691.1401, *et seq.*, the Federal Tort Claims Act, 28 U.S.C. 2671 *et seq.*, or the common law.
8. **Data Ownership.** Business Associate 2 has no ownership rights in the PHI. The covered entity retains all ownership rights of the PHI.
9. **Disclaimer.** Neither Business Associate 1, nor the Covered Entity, warrants or represents that compliance by Business Associate 2 with this Agreement, HIPAA, or the HIPAA Rules will be adequate or satisfactory for Business Associate 2's own purposes. Business Associate 2 is solely responsible for all decisions made by Business Associate 2 regarding the safeguarding of PHI.
10. **Certification.** If the Covered Entity determines an examination is necessary to comply with the Covered Entity's legal obligations under HIPAA relating to certification of its security practices, the Covered Entity or its authorized agents or contractors, may, at the Covered Entity's expense, examine Business Associate 2's facilities, systems, procedures and records as may be necessary for such agents or contractors to certify to the Covered Entity the extent to which Business Associate 2's security safeguards comply with HIPAA, the HIPAA Rules or this Agreement.
11. **Amendment.** The parties acknowledge that state and federal laws relating to data security and privacy are rapidly evolving and that amendment of this Agreement may be required to provide for procedures to ensure compliance with such developments. The parties specifically agree to take such action as is necessary to implement the standards and requirements of HIPAA and the HIPAA Rules. Upon the request of either party, the other party agrees to promptly enter into negotiations concerning the terms of an amendment to this Agreement embodying written assurances consistent with the standards and requirements of HIPAA and the HIPAA Rules. Either party may terminate the Agreement upon thirty days written notice if (i) one party does not promptly enter into negotiations to amend this Agreement when requested by the other party or (ii) Business Associate 2 does not enter into an amendment to this Agreement providing assurances regarding the safeguarding of PHI that the Covered Entity, in its sole discretion, deems sufficient to satisfy the standards and requirements of HIPAA or the HIPAA Rules.
12. **Assistance in Litigation or Administrative Proceedings.** Business Associate 2 must make itself, and any subcontractors, employees or agents assisting Business Associate 2 in the performance of its obligations under this Agreement, available to the Covered Entity or Business Associate 1, at no cost to the Covered Entity or Business Associate 1, to testify as witnesses, or otherwise, if litigation or administrative proceedings are commenced against the Covered Entity or Business Associate 1, its directors, officers or employees, departments, agencies, or divisions based upon a claimed violation of HIPAA or the HIPAA Rules or other laws relating to Business Associate 2's or its subcontractors use or disclosure of PHI under this Agreement, except where Business Associate 2 or its subcontractor, employee or agent is a named adverse party.

13. No Third-Party Beneficiaries. Nothing express or implied in this Agreement is intended to confer upon any person other than the Covered Entity, Business Associate 1, Business Associate 2 and their respective successors or assigns, any rights, remedies, obligations or liabilities whatsoever.

14. Interpretation and Order of Precedence. Any ambiguity in this Agreement must be interpreted to permit compliance with the HIPAA Rules. Where the provisions of this Agreement differ from those mandated by the HIPAA Rules, but are nonetheless permitted by the HIPAA Rules, the provisions of this Agreement control.

15. Effective Date. This Agreement is effective upon receipt of the last approval necessary and the affixing of the last signature required.

16. Survival of Certain Agreement Terms. Notwithstanding any contrary provision in this Agreement, the Business Associate 2's obligations under Section 6(d) and record retention laws ("Effect of Termination") and Section 12 ("No Third-Party Beneficiaries") survive termination of this Agreement and are enforceable by the Covered Entity or Business Associate 1.

17. Representatives and Notice.

a. Representatives. The individuals listed below are designated as the parties' respective representatives for purposes of this Agreement. Either party may from time to time designate in writing new or substitute representatives.

b. Notices. All required notices must be in writing and must be hand delivered or given by certified or registered mail to the representatives at the addresses set forth below.

Covered Entity Representative **[Replace this if Covered Entity is not DHHS]:**

James Bowen
Privacy and Security Manager
MDHHS Compliance Office
333 South Grand Ave, 4th Floor
Lansing, MI 48933
(517) 284-1018

MDHHSPrivacySecurity@michigan.gov

Business Associate 1 Representative **[Insert DTMB Representative here – Buyer for non-IT, BRM for IT]:**

Name:
Title:
Department:
Address:
Phone:
Email:

Business Associate 2 Representative:

Name:
Title:
Department:

Address:

Phone:

Email:

Any notice given to a party under this Agreement shall be deemed effective, if addressed to such party, upon: (i) delivery, if hand delivered; or (ii) the third Business Day after being sent by certified or registered mail.

**DTMB as Business Associate 1, on
behalf of [Covered Entity]**

Business Associate 2

[INSERT NAME]

By: _____

By: _____

Date: _____

Date: _____

Print Name: _____

Print Name: _____

Title: _____

Title: _____

The parties agree that, if the State determines that State or federal rules or regulations require the appendage of the specific contractual language contained in this addendum, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

FEDERAL BUREAU OF INVESTIGATION CRIMINAL JUSTICE INFORMATION SERVICES SECURITY ADDENDUM

The goal of this document is to augment the CJIS Security Policy to ensure adequate security is provided for criminal justice systems while (1) under the control or management of a private entity or (2) connectivity to FBI CJIS Systems has been provided to a private entity (contractor). Adequate security is defined in Office of Management and Budget Circular A- 130 as “security commensurate with the risk and magnitude of harm resulting from the loss, misuse, or unauthorized access to or modification of information.”

The intent of this Security Addendum is to require that the Contractor maintain a security program consistent with federal and state laws, regulations, and standards (including the CJIS Security Policy in effect when the contract is executed), as well as with policies and standards established by the Criminal Justice Information Services (CJIS) Advisory Policy Board (APB).

This Security Addendum identifies the duties and responsibilities with respect to the installation and maintenance of adequate internal controls within the contractual relationship so that the security and integrity of the FBI's information resources are not compromised. The security program shall include consideration of personnel security, site security, system security, and data security, and technical security.

The provisions of this Security Addendum apply to all personnel, systems, networks and support facilities supporting and/or acting on behalf of the government agency.

1. Definitions

1. Contracting Government Agency (CGA) - the government agency, whether a Criminal Justice Agency or a Noncriminal Justice Agency, which enters into an agreement with a private contractor subject to this Security Addendum.

2. Contractor - a private business, organization or individual which has entered into an agreement for the administration of criminal justice with a Criminal Justice Agency or a Noncriminal Justice Agency.

1. Responsibilities of the Contracting Government Agency.

1. The CGA will ensure that each Contractor employee receives a copy of the Security Addendum and the CJIS Security Policy and executes an acknowledgment of such receipt and the contents of the Security Addendum. The signed acknowledgments shall remain in the possession of the CGA and available for audit purposes. The acknowledgement may be signed by hand or via digital signature (see glossary for definition of digital signature).

1. Responsibilities of the Contractor.

1. The Contractor will maintain a security program consistent with federal and state laws, regulations, and standards (including the CJIS Security Policy in effect when the contract is executed and all subsequent versions), as well as with policies and standards established by the Criminal Justice Information Services (CJIS) Advisory Policy Board (APB).

1. Security Violations.
 1. The CGA must report security violations to the CJIS Systems Officer (CSO) and the Director, FBI, along with indications of actions taken by the CGA and Contractor.
 2. Security violations can justify termination of the appended agreement.
 3. Upon notification, the FBI reserves the right to:
 - a. Investigate or decline to investigate any report of unauthorized use;
 - b. Suspend or terminate access and services, including telecommunications links. The FBI will provide the CSO with timely written notice of the suspension. Access and services will be reinstated only after satisfactory assurances have been provided to the FBI by the CGA and Contractor. Upon termination, the Contractor's records containing CHRI must be deleted or returned to the CGA.
1. Audit
 1. The FBI is authorized to perform a final audit of the Contractor's systems after termination of the Security Addendum.
1. Scope and Authority
 1. This Security Addendum does not confer, grant, or authorize any rights, privileges, or obligations on any persons other than the Contractor, CGA, CJA (where applicable), CSA, and FBI.
 2. The following documents are incorporated by reference and made part of this agreement: (1) the Security Addendum; (2) the NCIC 2000 Operating Manual; (3) the CJIS Security Policy; and (4) Title 28, Code of Federal Regulations, Part 20. The parties are also subject to applicable federal and state laws and regulations.
 3. The terms set forth in this document do not constitute the sole understanding by and between the parties hereto; rather they augment the provisions of the CJIS Security Policy to provide a minimum basis for the security of the system and contained information and it is understood that there may be terms and conditions of the appended Agreement which impose more stringent requirements upon the Contractor.
 4. This Security Addendum may only be modified by the FBI, and may not be modified by the parties to the appended Agreement without the consent of the FBI.
 5. All notices and correspondence shall be forwarded by First Class mail to:

Information Security Officer
Criminal Justice Information Services Division, FBI
1000 Custer Hollow Road
Clarksburg, West Virginia 26306

**FEDERAL BUREAU OF INVESTIGATION
CRIMINAL JUSTICE INFORMATION SERVICES
SECURITY ADDENDUM**

CERTIFICATION

I hereby certify that I am familiar with the contents of (1) the Security Addendum, including its legal authority and purpose; (2) the NCIC Operating Manual; (3) the CJIS Security Policy; and (4) Title 28, Code of Federal Regulations, Part 20, and agree to be bound by their provisions.

I recognize that criminal history record information and related data, by its very nature, is sensitive and has potential for great harm if misused. I acknowledge that access to criminal history record information and related data is therefore limited to the purpose(s) for which a government agency has entered into the contract incorporating this Security Addendum. I understand that misuse of the system by, among other things: accessing it without authorization; accessing it by exceeding authorization; accessing it for an improper purpose; using, disseminating or re-disseminating information received as a result of this contract for a purpose other than that envisioned by the contract, may subject me to administrative and criminal penalties. I understand that accessing the system for an appropriate purpose and then using, disseminating or re-disseminating the information received for another purpose other than execution of the contract also constitutes misuse. I further understand that the occurrence of misuse does not depend upon whether or not I receive additional compensation for such authorized activity. Such exposure for misuse includes, but is not limited to, suspension or loss of employment and prosecution for state and federal crimes.

Printed Name/Signature of Contractor Employee Date

Printed Name/Signature of Contractor Representative Date

Organization and Title of Contractor Representative

The parties agree that, if the State determines that State or federal rules or regulations require the appendage of the specific contractual language contained in this exhibit, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

Exhibit 7 Safeguarding Contract Language

I. PERFORMANCE

In performance of this contract, the Contractor agrees to comply with and assume responsibility for compliance by officers or employees with the following requirements:

- (1) All work will be performed under the supervision of the contractor.
- (2) The contractor and contractor's officers or employees to be authorized access to FTI must meet background check requirements defined in IRS Publication 1075. The contractor will maintain a list of officers or employees authorized access to FTI. Such list will be provided to the agency and, upon request, to the IRS.
- (3) FTI in hardcopy or electronic format shall be used only for the purpose of carrying out the provisions of this contract. FTI in any format shall be treated as confidential and shall not be divulged or made known in any manner to any person except as may be necessary in the performance of this contract. Inspection or disclosure of FTI to anyone other than the contractor or the contractor's officers or employees authorized is prohibited.
- (4) FTI will be accounted for upon receipt and properly stored before, during, and after processing. In addition, any related output and products require the same level of protection as required for the source material.
- (5) The contractor will certify that FTI processed during the performance of this contract will be completely purged from all physical and electronic data storage with no output to be retained by the contractor at the time the work is completed. If immediate purging of physical and electronic data storage is not possible, the contractor will certify that any FTI in physical or electronic storage will remain safeguarded to prevent unauthorized disclosures.
- (6) Any spoilage or any intermediate hard copy printout that may result during the processing of FTI will be given to the agency. When this is not possible, the contractor will be responsible for the destruction of the spoilage or any intermediate hard copy printouts and will provide the agency with a statement containing the date of destruction, description of material destroyed, and the destruction method.
- (7) All computer systems receiving, processing, storing, or transmitting FTI must meet the requirements in IRS Publication 1075. To meet functional and assurance requirements, the security features of the environment must provide for the managerial, operational, and technical controls. All security features must be available and activated to protect against unauthorized use of and access to FTI.
- (8) No work involving FTI furnished under this contract will be subcontracted without the prior written approval of the IRS.
- (9) Contractor will ensure that the terms of FTI safeguards described herein are included, without modification, in any approved subcontract for work involving FTI.
- (10) To the extent the terms, provisions, duties, requirements, and obligations of this contract apply to performing services with FTI, the contractor shall assume toward the subcontractor all obligations, duties and responsibilities that the agency under this contract assumes toward the contractor, and the subcontractor shall assume toward the contractor all the same obligations, duties and responsibilities which the contractor assumes toward the agency under this contract.
- (11) In addition to the subcontractor's obligations and duties under an approved subcontract, the terms and conditions of this contract apply to the subcontractor, and the subcontractor is bound and obligated to the contractor hereunder by the same terms and conditions by which the contractor is bound and obligated to the agency under this contract.
- (12) For purposes of this contract, the term "contractor" includes any officer or employee of the contractor with access to or who uses FTI, and the term "subcontractor" includes any officer or employee of the subcontractor with access to or who uses FTI.
- (13) The agency will have the right to void the contract if the contractor fails to meet the terms of FTI safeguards described herein.

II. CRIMINAL/CIVIL SANCTIONS

- (1) Each officer or employee of a contractor to whom FTI is or may be disclosed shall be notified in writing that FTI disclosed to such officer or employee can be used only for a purpose and to the extent authorized herein, and that further disclosure of any FTI for a purpose not authorized herein constitutes a felony punishable upon

conviction by a fine of as much as \$5,000 or imprisonment for as long as 5 years, or both, together with the costs of prosecution.

(2) Each officer or employee of a contractor to whom FTI is or may be accessible shall be notified in writing that FTI accessible to such officer or employee may be accessed only for a purpose and to the extent authorized herein, and that access/inspection of FTI without an official need-to-know for a purpose not authorized herein constitutes a criminal misdemeanor punishable upon conviction by a fine of as much as \$1,000 or imprisonment for as long as 1 year, or both, together with the costs of prosecution.

(3) Each officer or employee of a contractor to whom FTI is or may be disclosed shall be notified in writing that any such unauthorized access, inspection or disclosure of FTI may also result in an award of civil damages against the officer or employee in an amount equal to the sum of the greater of \$1,000 for each unauthorized access, inspection, or disclosure, or the sum of actual damages sustained as a result of such unauthorized access, inspection, or disclosure, plus in the case of a willful unauthorized access, inspection, or disclosure or an unauthorized access/inspection or disclosure which is the result of gross negligence, punitive damages, plus the cost of the action. These penalties are prescribed by IRC sections 7213, 7213A and 7431 and set forth at 26 CFR 301.6103(n)-1.

(3) Additionally, it is incumbent upon the contractor to inform its officers and employees of the penalties for improper disclosure imposed by the Privacy Act of 1974, 5 U.S.C. 552a. Specifically, 5 U.S.C. 552a(i)(1), which is made applicable to contractors by 5 U.S.C. 552a(m)(1), provides that any officer or employee of a contractor, who by virtue of his/her employment or official position, has possession of or access to agency records which contain individually identifiable information, the disclosure of which is prohibited by the Privacy Act or regulations established thereunder, and who knowing that disclosure of the specific material is so prohibited, willfully discloses the material in any manner to any person or agency not entitled to receive it, shall be guilty of a misdemeanor and fined not more than \$5,000.

(4) Granting a contractor access to FTI must be preceded by certifying that each officer or employee understands the agency's security policy and procedures for safeguarding FTI. A contractor and each officer or employee must maintain their authorization to access FTI through annual recertification of their understanding of the agency's security policy and procedures for safeguarding FTI. The initial certification and recertifications must be documented and placed in the agency's files for review. As part of the certification and at least annually afterwards, a contractor and each officer or employee must be advised of the provisions of IRC sections 7213, 7213A, and 7431 (see Exhibit 4, Sanctions for Unauthorized Disclosure, and Exhibit 5, Civil Damages for Unauthorized Disclosure). The training on the agency's security policy and procedures provided before the initial certification and annually thereafter must also cover the incident response policy and procedure for reporting unauthorized disclosures and data breaches. (See Section 10) For the initial certification and the annual recertifications, the contractor and each officer or employee must sign, either with ink or electronic signature, a confidentiality statement certifying their understanding of the security requirements.

III. INSPECTION

The IRS and the Agency, with 24 hour notice, shall have the right to send its inspectors into the offices and plants of the contractor to inspect facilities and operations performing any work with FTI under this contract for compliance with requirements defined in IRS Publication 1075. The IRS' right of inspection shall include the use of manual and/or automated scanning tools to perform compliance and vulnerability assessments of information technology (IT) assets that access, store, process or transmit FTI. Based on the inspection, corrective actions may be required in cases where the contractor is found to be noncompliant with FTI safeguard requirements.

BIDDER INSTRUCTIONS

Do you accept these Data Security Requirements as presented?

BIDDER RESPONSE:

[See response on page 151.](#)

If Bidder takes exceptions to these provisions, bidder must redline these terms as part of its proposal response. Exceptions to the terms may be grounds for disqualification at the State's discretion. General statements, such as that the Bidder reserves the right to negotiate the terms and conditions, may be deemed non-responsive.

SCHEDULE F – DISASTER RECOVERY PLAN

BIDDER INSTRUCTIONS

Please provide a link to Bidder's Disaster Recovery Plan.

BIDDER RESPONSE:

Broad range of flexible business continuity solutions. These solutions are based on our proven cloud platform, offered across a global, secure network of cloud regions. From high-bandwidth file synchronization to zero data loss database protection and detailed database failover options, Oracle Cloud offers scalable, reliable, secure, and extremely cost-effective resiliency and disaster recovery (DR) solutions.

More information can be found at <https://www.oracle.com/cloud/backup-and-disaster-recovery/>.

SCHEDULE G – TRANSITION IN AND OUT

BIDDER INSTRUCTIONS

Bidder must provide a detailed transition-in and transition-out plan, including any roles or responsibilities expected of the State. The plan must demonstrate the steps to migrate services between Bidder and a third-party or the State.

BIDDER RESPONSE:

Oracle interpreted his requirement as the onboarding and offloading to/from OCI.

Transition into OCI (from Oracle Cloud Service Agreement)

We will make the Oracle services listed in Your order (the “Services”) available to You pursuant to this Agreement and Your order. Except as otherwise stated in this Agreement or Your order, You have the non-exclusive, worldwide, limited right to use the Services during the period defined in Your order, unless earlier terminated in accordance with this Agreement or Your order (the “Services Period”), solely for Your internal business operations. You may allow Your Users (as defined below) to use the Services for this purpose, and You are responsible for their compliance with this Agreement and Your order.

The Service Specifications describe and govern the Services. During the Services Period, we may update the Services and Service Specifications to reflect changes in, among other things, laws, regulations, rules, technology, industry practices, patterns of system use, and availability of Third Party Content (as defined below). Oracle updates to the Services or Service Specifications will not materially reduce the level of performance, functionality, security or availability of the Services during the Services Period of Your order.

Transition from OCI

For a period of 60 days upon termination of the Oracle Cloud Services, Oracle will make available, via secure protocols and in a structured, machine-readable format, Your Content residing in the production Oracle Cloud Services, or keep the service system accessible, for the purpose of data retrieval by You.

Oracle has no obligation to retain Your Content after this retrieval period.

If You need assistance from Oracle to obtain access to or copies of Your Content, You must create a service request in the Cloud Customer Support Portal applicable to the service (e.g., My Oracle Support).

Data retrieval and any related assistance by Oracle is not applicable for Oracle Cloud Services that do not store Your Content. You are responsible for ensuring that if those Oracle Cloud Services are dependent on separate Oracle Cloud Services (such as Storage Cloud Service or Database Cloud Services) for the storage of data, those separate Oracle Cloud Services must have a valid duration through the end of the terminating Oracle Cloud Service to enable data retrieval, or for otherwise taking appropriate action to back up or otherwise store separately Your Content while the production Oracle Cloud Services is still active prior to termination.

Following expiry of the retrieval period, Oracle will delete Your Content from the Oracle Cloud Services (unless otherwise required by applicable law).

For Oracle Cloud at Customer Services, You must make available for retrieval by Oracle any Oracle Cloud at Customer Service-related hardware components (including the gateway equipment) provided by Oracle in good working order and the same condition as at the start of the Oracle Cloud at Customer Services subject to reasonable wear and tear for appropriate use.

Upon termination of services (as described in the Oracle Cloud Suspension and Termination Policy) or at Customer's request, Oracle will delete environments or data residing therein in a manner designed to ensure that they cannot reasonably be accessed or read, unless there is a legal obligation imposed on Oracle preventing it from deleting all or part of the environments or data.

SCHEDULE H – RESERVED-

SCHEDULE J – FEDERAL PROVISIONS ADDENDUM

BIDDER INSTRUCTIONS

NOTE: Neither the State nor Contractor may alter these federally required provisions.
Do you accept these Federal Provisions as presented?

BIDDER RESPONSE:

If federal rules or regulations require the appendage of the specific contractual language contained in this exhibit, Oracle will append the required contractual language, as mutually agreed by the parties, to the ordering document. In the event that Oracle, in its sole discretion, determines that it cannot comply with the required contractual language, the workloads shall not be part of the scope.

Contractor acknowledges and agrees that the State may utilize funds obtained from the federal government which may have additional contractual requirements. Contractor agrees that, if the State determines that federal rules or regulations require the appendage of specific contractual language to this Contract related to specific types of federal funding, including but not limited to [Title 2 of the Code of Federal Regulations \(C.F.R.\) Part 200](#) and [Appendix II to Part 200 – Contract Provisions for Non-Federal Entity Contracts Under Federal Awards](#), Contractor agrees to, through a Contract Change Notice, append such required contractual language to this Contract if reasonably necessary to keep the State and Contractor in compliance with federal funding requirements and comply with the terms set forth therein.

This addendum applies to purchases that will be paid for in whole or in part with funds obtained from the federal government. The provisions below are required, and the language is not negotiable. Contractor agrees to comply with all obligations under federal rules or regulations for such funding, including but not limited to the provisions contained in this addendum. If any provision below conflicts with the State's terms and conditions, including any attachments, schedules, or exhibits to this Contract, the provisions below take priority to the extent a provision is required by federal law; otherwise, the order of precedence set forth in the Contract applies. Further, Contractor agrees to, through a Contract Change Notice, append or modify specific federal provisions to this Contract, if reasonably necessary to keep the State and Contractor in compliance with federal funding requirements, and comply with the terms set forth therein. Hyperlinks are provided for convenience only; broken hyperlinks will not relieve Contractor from compliance with the law.

A. Equal Employment Opportunity

This Contract is not a “**federally assisted construction contract**” as defined in [41 CFR Part 60-1.3](#).

B. Davis-Bacon Act (Prevailing Wage)

This Contract is not a “**federally assisted construction contract**” as defined in [41 CFR Part 60-1.3](#), nor is it a prime construction contract in excess of \$2,000.

C. Copeland “Anti-Kickback” Act

This Contract is not a “**federally assisted construction contract**” as defined in [41 CFR Part 60-1.3](#), nor is it a prime construction contract in excess of \$2,000 where the Davis-Bacon Act applies.

D. Contract Work Hours and Safety Standards Act

The Contract does not involve the employment of mechanics or laborers.

E. Rights to Inventions Made Under a Contract or Agreement

If this Contract is funded by a federal “funding agreement” as defined under [37 CFR §401.2 \(a\)](#) and the recipient or subrecipient wishes to enter into a contract with a small business firm or nonprofit organization regarding the substitution of parties, assignment or performance of experimental, developmental, or research work under that “funding agreement,” the recipient or subrecipient must comply with [37 CFR Part 401](#), “Rights to Inventions Made by Nonprofit Organizations and Small Business Firms Under Government Grants, Contracts and Cooperative Agreements,” and any implementing regulations issued by the awarding agency.

F. Clean Air Act and the Federal Water Pollution Control Act

If this Contract is in excess of \$150,000, the Contractor must comply with all applicable standards, orders, and regulations issued under the Clean Air Act ([42 USC 7401-7671q](#)) and the Federal Water Pollution Control Act ([33 USC 1251-1387](#)), and during performance of this Contract the Contractor agrees as follows:

- (1) Clean Air Act
 - (i) The Contractor agrees to comply with all applicable standards, orders or regulations issued pursuant to the Clean Air Act, as amended, 42 U.S.C. § 7401 et seq.
 - (ii) The Contractor agrees to report each violation to the State and understands and agrees that the State will, in turn, report each violation as required to assure notification to the Federal Emergency Management Agency or the applicable federal awarding agency, and the appropriate Environmental Protection Agency Regional Office.
 - (iii) The Contractor agrees to include these requirements in each subcontract exceeding \$150,000 financed in whole or in part with Federal assistance provided by FEMA or the applicable federal awarding agency.
- (2) Federal Water Pollution Control Act
 - (i) The Contractor agrees to comply with all applicable standards, orders, or regulations issued pursuant to the Federal Water Pollution Control Act, as amended, 33 U.S.C. 1251 et seq.
 - (ii) The Contractor agrees to report each violation to the State and understands and agrees that the State will, in turn, report each violation as required to assure notification to the Federal Emergency Management Agency or the applicable federal awarding agency, and the appropriate Environmental Protection Agency Regional Office.
 - (iii) The Contractor agrees to include these requirements in each subcontract exceeding \$150,000 financed in whole or in part with Federal assistance provided by FEMA or the applicable federal awarding agency.

G. Debarment and Suspension

A “contract award” (see [2 CFR 180 220](#)) must not be made to parties listed on the government-wide exclusions in the [System for Award Management \(SAM\)](#), in accordance with the OMB guidelines at [2 CFR 180](#) that implement [Executive Orders 12549 \(51 FR 6370: February 21, 1986\)](#) and 12689 ([54 FR 34131: August 18, 1989](#)), “Debarment and Suspension.” SAM Exclusions contains the names of parties debarred, suspended, or otherwise excluded by agencies, as well as parties declared ineligible under statutory or regulatory authority other than [Executive Order 12549](#).

- (1) This Contract is a covered transaction for purposes of 2 C.F.R. Part 180 and 2 C.F.R. Part 3000. As such, the Contractor is required to verify that none of the Contractor’s principals (defined at 2 C.F.R. § 180.995) or its affiliates (defined at 2 C.F.R. § 180.905) are excluded (defined at 2 C.F.R. § 180.940) or disqualified (defined at 2 C.F.R. § 180.935).
- (2) The Contractor must comply with 2 C.F.R. Part 180, subpart C and 2 C.F.R. Part 3000, subpart C, and must include a requirement to comply with these regulations in any lower tier covered transaction it enters into.
- (3) This certification is a material representation of fact relied upon by the State. If it is later determined that the contractor did not comply with 2 C.F.R. Part. 180, subpart C and 2 C.F.R. Part. 3000, subpart C, in addition to remedies available to the State, the Federal Government may pursue available remedies, including but not limited to suspension and/or debarment.
- (4) The bidder or proposer agrees to comply with the requirements of 2 C.F.R. Part 180, subpart C and 2 C.F.R. Part 3000, subpart C while this offer is valid and throughout the period of any contract that

may arise from this offer. The bidder or proposer further agrees to include a provision requiring such compliance in its lower tier covered transactions.

H. Byrd Anti-Lobbying Amendment, 31 U.S.C. § 1352 (as amended)

Contractor has applied or bid for an award of **more than \$100,000** and shall file the required certification in *Exhibit 1 – Byrd Anti-Lobbying Certification* attached to the end of this Addendum. Each tier certifies to the tier above that it will not and has not used federally appropriated funds to pay any person or organization for influencing or attempting to influence an officer or employee of any agency, a Member of Congress, officer or employee of Congress, or an employee of a Member of Congress in connection with obtaining any federal contract, grant, or any other award covered by 31 U.S.C. § 1352. Each tier shall also disclose any lobbying with non-federal funds that takes place in connection with obtaining any federal award. Such disclosures are forwarded from tier to tier up to the recipient who in turn will forward the certification(s) to the federal awarding agency.

I. Procurement of Recovered Materials

If this Contract is a procurement to purchase products or items designated by the EPA under [40 C.F.R. part 247](#) during the course of a fiscal year, then under [2 CFR 200.323](#), Contractors must comply with section 6002 of the Solid Waste Disposal Act, as amended by the Resource Conservation and Recovery Act.

- (1) In the performance of this contract, the Contractor shall make maximum use of products containing recovered materials that are EPA-designated items unless the product cannot be acquired:
 - (i) Competitively within a timeframe providing for compliance with the contract performance schedule;
 - (ii) Meeting contract performance requirements; or
 - (iii) At a reasonable price.
- (2) Information about this requirement, along with the list of EPA- designated items, is available at EPA's Comprehensive Procurement Guidelines web site, <https://www.epa.gov/smm/comprehensive-procurement-guideline-cpg-program>.
- (3) The Contractor also agrees to comply with all other applicable requirements of Section 6002 of the Solid Waste Disposal Act.

J. Prohibition on Contracting for Covered Telecommunications Equipment or Services

Contractor acknowledges and agrees that [Section 889\(b\) of the John S. McCain National Defense Authorization Act for Fiscal Year 2019 Pub. L. No. 115-232 \(the "McCain Act"\)](#), and [2 C.F.R. §200.216](#), prohibit the obligation or expending of federal award funds on certain telecommunication products or with certain entities for national security reasons on or after August 13, 2020.

During performance of this Contract, the Contractor agrees as follows:

- (a) *Definitions.* As used in this Section J. Prohibition on Contracting for Covered Telecommunications Equipment or Services ("Section J"):
 - (1) the terms "backhaul," "critical technology," "interconnection arrangements," "reasonable inquiry," "roaming," and "substantial or essential component" have the meanings defined in 48 CFR § 4.2101;
 - (2) the term "covered foreign country" has the meanings defined in § 889(f)(2) of the McCain Act; and
 - (3) the term "covered telecommunications equipment or services" has the meaning defined in § 889(f)(3) of the McCain Act.

(b) Prohibitions.

- (1) Unless an exception in paragraph (c) of this Section J applies, neither the Contractor nor any of its subcontractors may use funds received under this Contract to:
 - (i) Procure or obtain any equipment, system, or service that uses covered telecommunications equipment or services as a substantial or essential component of any system, or as critical technology of any system;
 - (ii) Enter into, extend, or renew a contract to procure or obtain any equipment, system, or service that uses covered telecommunications equipment or services as a substantial or essential component of any system, or as critical technology of any system;
 - (iii) Enter into, extend, or renew a contract with an entity that uses any covered telecommunications equipment or services as a substantial or essential component of any system, or as critical technology as part of any system; or
 - (iv) Provide, as part of its performance of this contract, subcontract, or other contractual instrument, any equipment, system, or service that uses covered telecommunications equipment or services as a substantial or essential component of any system, or as critical technology as part of any system.

(c) Exceptions.

- (1) This Section J does not prohibit Contractor from providing—
 - (i) A service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements; or
 - (ii) Telecommunications equipment that cannot route or redirect user data traffic or permit visibility into any user data or packets that such equipment transmits or otherwise handles.

(d) Reporting requirement.

- (1) In the event the Contractor identifies covered telecommunications equipment or services used as a substantial or essential component of any system, or as critical technology as part of any system, during contract performance, or the contractor is notified of such by a subcontractor at any tier or by any other source, the Contractor shall report the information in paragraph (d)(2) of this Section J to the recipient or subrecipient, unless elsewhere in this contract are established procedures for reporting the information.
- (2) The Contractor shall report the following information pursuant to paragraph (d)(1) of this Section J:
 - (i) Within one business day from the date of such identification or notification: The contract number; the order number(s), if applicable; supplier name; supplier unique entity identifier (if known); supplier Commercial and Government Entity (CAGE) code (if known); brand; model number (original equipment manufacturer number, manufacturer part number, or wholesaler number); item description; and any readily available information about mitigation actions undertaken or recommended.
 - (ii) Within 10 business days of submitting the information in paragraph (d)(2)(i) of this Section J: Any further available information about mitigation actions undertaken or recommended. In addition, the contractor shall describe the efforts it undertook to prevent use or submission of covered telecommunications

equipment or services, and any additional efforts that will be incorporated to prevent future use or submission of covered telecommunications equipment or services.

- (e) *Subcontracts*. The Contractor shall insert the substance of this Section J, including this paragraph (e), in all subcontracts and other contractual instruments.

K. Domestic Preferences for Procurements

As appropriate, and to the extent consistent with law, the Contractor should, to the greatest extent practicable, provide a preference for the purchase, acquisition, or use of goods, products, or materials produced in the United States. This includes, but is not limited to iron, aluminum, steel, cement, and other manufactured products.

For purposes of this Section K – Domestic Preferences for Procurements:

“Produced in the United States” means, for iron and steel products, that all manufacturing processes, from the initial melting stage through the application of coatings, occurred in the United States.

1. ***“Manufactured products” mean items and construction materials composed in whole or in part of non-ferrous metals such as aluminum; plastics and polymer-based products such as polyvinyl chloride pipe; aggregates such as concrete; glass, including optical fiber; and lumber.***

L. Affirmative Socioeconomic Steps

For all contracts utilizing federal funding sources subject to Title 2 of the Code of Federal Regulations (C.F.R.) Part 200 issued on or after November 12, 2020, if subcontracts are to be let, the prime contractor is required to take all necessary steps identified in 2 C.F.R. § 200.321(b)(1)-(5) to ensure that small and minority businesses, women’s business enterprises, and labor surplus area firms are used when possible.

M. Copyright and Data Rights

Pursuant to 2 CFR § 200.315(b), the State may copyright any work which is subject to copyright and was developed, or for which ownership was acquired, under a Federal award. The Federal awarding agency reserves a royalty-free, nonexclusive and irrevocable right to reproduce, publish, or otherwise use the work for Federal purposes, and to authorize others to do so.

N. Additional FEMA Contract Provisions

This Contract does not involve purchases that will be paid for in whole or in part with funds obtained from the Federal Emergency Management Agency (FEMA).

O. Other Federal Contract Provisions

No additional federal provisions currently apply to this Contract.

SCHEDULE J - EXHIBIT 1

Byrd anti-lobbying certification

BIDDER INSTRUCTIONS

NOTE: Neither the State nor Contractor may alter these federally required provisions.
Do you accept these Federal Provisions as presented?

BIDDER RESPONSE:

Please see the file, *Schedule J – Exhibit 1-Oracle pdf*, included with Oracle's response.

Contractor must complete this certification if the purchase will be paid for in whole or in part with funds obtained from the federal government and the purchase is greater than \$100,000.

APPENDIX A, 44 C.F.R. PART 18 – CERTIFICATION REGARDING LOBBYING

Certification for Contracts, Grants, Loans, and Cooperative Agreements

The undersigned certifies, to the best of his or her knowledge and belief, that:

1. No Federal appropriated funds have been paid or will be paid, by or on behalf of the undersigned, to any person for influencing or attempting to influence an officer or employee of an agency, a Member of Congress, an officer or employee of Congress, or an employee of a Member of Congress in connection with the awarding of any Federal contract, the making of any Federal grant, the making of any Federal loan, the entering into of any cooperative agreement, and the extension, continuation, renewal, amendment, or modification of any Federal contract, grant, loan, or cooperative agreement.
2. If any funds other than Federal appropriated funds have been paid or will be paid to any person for influencing or attempting to influence an officer or employee of any agency, a Member of Congress, an officer or employee of Congress, or an employee of a Member of Congress in connection with this Federal contract, grant, loan, or cooperative agreement, the undersigned shall complete and submit Standard Form-LLL, "Disclosure Form to Report Lobbying," in accordance with its instructions.
3. The undersigned shall require that the language of this certification be included in the award documents for all subawards at all tiers (including subcontracts, subgrants, and contracts under grants, loans, and cooperative agreements) and that all subrecipients shall certify and disclose accordingly.

This certification is a material representation of fact upon which reliance was placed when this transaction was made or entered into. Submission of this certification is a prerequisite for making or entering into this transaction imposed by section 1352, Title 31, U.S. C. Any person who fails to file the required certification shall be subject to a civil penalty of not less than \$10,000 and not more than \$100,000 for each such failure. The Contractor, **enter contractor name here**, certifies or affirms the truthfulness and accuracy of each statement of its certification and disclosure, if any. In addition, the Contractor understands and agrees that the provisions of 31 U.S.C. Chap. 38, Administrative Remedies for False Claims and Statements, apply to this certification and disclosure, if any.

Signature of Contractor's Authorized Official

Name and Title of Contractor's Authorized Official

Date